

Open in app ↗

Sign up

Sign in

Medium

🔍 Search



Smile, You're on Camera: A Live Stream from Inside Lazarus Group's IT Workers Scheme

23 min read · Dec 4, 2025



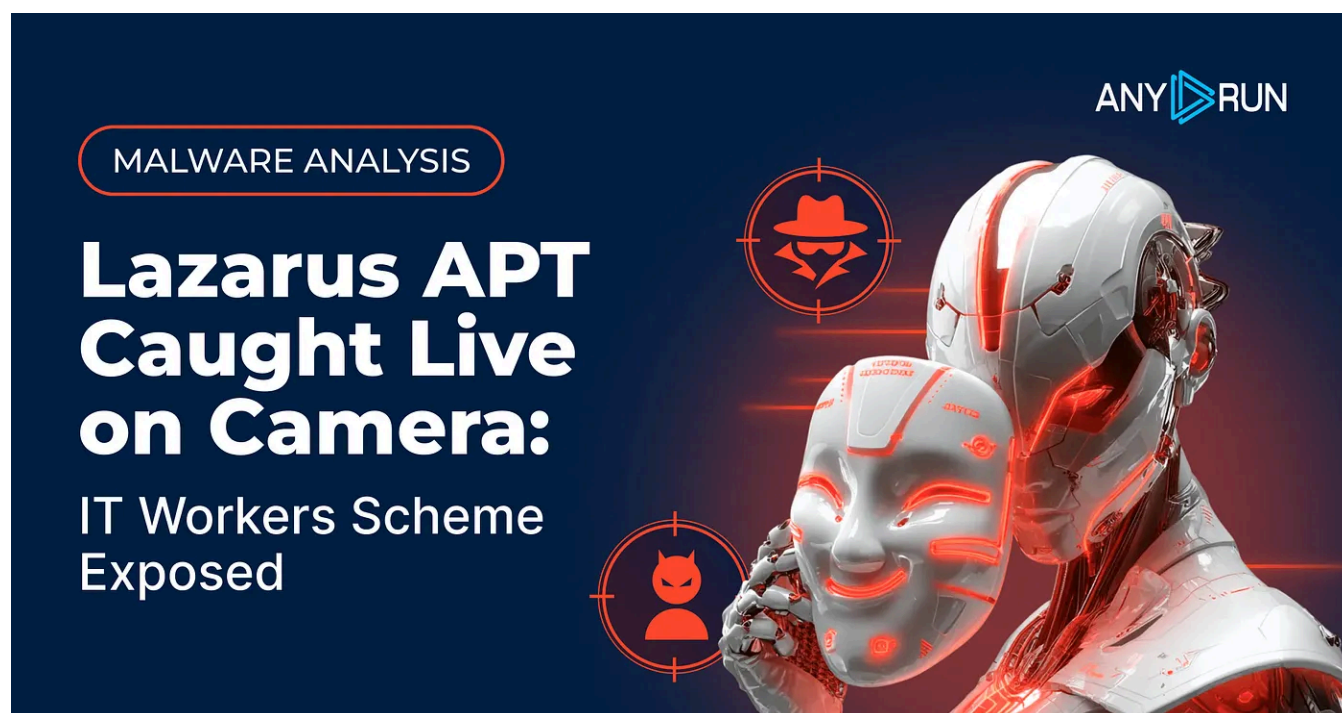
ANY.RUN



Listen



Share



Editor's note: This work is a collaboration between Mauro Eldritch from BCA LTD, a company dedicated to threat intelligence and hunting, Heiner García from NorthScan, a threat intelligence initiative uncovering North Korean IT worker infiltration, and ANY.RUN, the leading malware analysis and threat intelligence provider. The article was written by Mauro and Heiner.

In this article, we'll uncover an entire **North Korean infiltration operation** aimed at deploying **remote IT workers** across different companies in the American **financial** and **crypto/Web3** sectors, with the objective of conducting **corporate espionage** and

generating **funding** for the sanctioned regime. We attributed this effort to the **state-sponsored APT** (Advanced Persistent Threat) **Lazarus**, specifically the **Famous Chollima** division.

Key Takeaways

- **North Korean operators are infiltrating companies** by posing as remote IT workers and using stolen or rented identities.
- **Famous Chollima relies on social engineering**, not advanced malware, convincing stories, pressure, and identity fraud drive the operation.
- **Recruitment is wide-scale**, using GitHub spam, Telegram outreach, and fake job-seeking setups.
- **Victims are pushed to hand over full identity data**, including SSNs, bank accounts, and device access.
- **Extended ANY.RUN sandbox environments enabled real-time monitoring**, capturing every click, file action, and network request.
- **Operators used a predictable toolkit**, including AnyDesk, Google Remote Desktop, AI-based interview helpers, and OTP extensions.
- **Shared infrastructure and repeated mistakes** revealed their poor operational security and overlapping roles.
- **Controlled crashes and resets** kept them contained, preventing any real malicious activity while intelligence was gathered.
- **The investigation provides a rare inside view** of how these operatives work, communicate, and attempt to maintain access.

How the Investigation Was Set Up

We divided this effort into two stages: approaching one of their **recruiters**, building a trusted relationship, and receiving an offer to help them set up **laptops** “to work” (conducted by **Heiner García** from **NorthScan**), and then setting up a simulated **laptop farm** using **sandboxed environments** provided by **ANY.RUN**, to record their activity in real-time and analyze their **toolchain and TTPs** (conducted by **Mauro Eldritch** from **BCA LTD**). Controlled crashes and resets kept them contained, preventing any real malicious activity while intelligence was gathered.

All interviews with DPRK agents and their activities on the laptop farm were recorded from start to finish, in an unprecedented effort that publicly documents their operations from the inside for the first time.



Introduction: The Spies

Introducing Famous Chollima | Mauro Eldritch (BCA LTD)

There's a long story of cyber heists conducted by the **Lazarus Group**. They are among the *most creative* threat actors: from hacking **cryptocurrency exchanges** and **crypto bridges** to conducting **fake job interviews**, they've done it all.

Their **social engineering** tactics are often daring. In one scheme, they set up fake job interviews targeting **crypto developers** with **malicious coding challenges**. In another, they pose as **fake VC investors** targeting startups. During these calls, the "investors" **pretend they cannot hear the victims** no matter what, suggesting to re-schedule the call later. Eventually, one participant shares a "Zoom fix", and whilst panicking about losing their funding opportunity, the victims run it and **infect themselves**.

Over the last few years, I've analyzed different strains of their malware (and have even discovered and named some of them myself).

None were particularly clever or sophisticated at all, but that taught me something important which is core to this research: when you fall for **Lazarus**, most of the time you don't fall for zero days or complex exploit chains; **you fall for a good story**. They may be mediocre programmers, but they are **great actors**, indeed. And this is what **Famous Chollima** is all about: (almost) **no malware, pure acting**.

This division focuses on **obtaining jobs in Western companies**, especially in the **finance, crypto and healthcare** sectors, but has recently expanded its operations to include the **civil engineering and architecture** sectors. Once inside the organizations, they may conduct **corporate espionage**, whilst also obtaining clean funds that are ultimately channeled back to the **Democratic People's Republic of Korea**, a sanctioned regime. It is believed that these funds ultimately go towards the **development of their ballistic missiles programme**.

To obtain the jobs, two methods of operation become clear: the first where the **threat actors steal identities and CVs** from other engineers and **attend meetings themselves**, in a daredevil stunt that was **highly observed** during this investigation; and the second one where **they lure engineers** (especially junior ones) **into "working for them"**.

They declare having a company of 10 or so developers and only need the victim engineer to **attend the interviews on their behalf**, while receiving technical help to pass them. If hired, the victim receives a 35% cut of the monthly salary, while the operatives handle the actual work through "ghost developers."

The engineer has to accept the offer, **receive the company equipment (laptop)** and allow one of the "ghost developers" to remotely log in to "work". Amongst his few responsibilities are **attending the daily stand-ups** and **taking occasional calls where he should show his face**.

While the offer seems tempting for many, the engineer is actually **renting out their own identity** and will ultimately be **the sole person responsible for any material, intellectual, reputational or monetary damage** done to the victim companies.

Federal agencies have already **conducted arrests** for these operations and are **actively looking to disband both laptop farms and IT worker clusters**.

Lazarus Group's IT Workers Scheme Caught on Live Camera



"Mateo"



"Julián"



"Aaron"



"Jesús"



"Sebastián"



"Alfredo"

Source: Bitso Quetzal Team (Mateo, Julián, Jesús, Sebastián, Alfredo), NorthScan (Aaron)

During my time leading Bitso's Quetzal Team (LATAM's first Web3 Threats Research Team) I managed to document our encounters with different Lazarus divisions, be it in the form of them trying to trick us into running malware or this newer division attempting to get a job with us. For this last case, I documented an extended saga which I titled "Interview with the Chollima" where we recorded them when interacting and gathering intelligence.

For now, this should be enough of an introduction to our hosts today. They are not monsters; they are **normal** people amongst us, just a few clicks and a job posting away from entering our lives or **becoming a coworker**.

So, for the next chapter, we need that to happen. **One of us needs to be recruited.**

Heiner took that role; the bravest among us!

Chapter I: The Rookie

Getting recruited by Famous Chollima | Heiner García (NorthScan)

The first approach with their recruiter was via **GitHub**. A cluster of accounts was **spamming repositories** with a strange message:

I have reviewed your Github and LinkedIn profile.

Really appreciated at your good skills.

I'd like to offer you an opportunity that I think could be interesting.

I run a US-based job hunting business, and I noticed you had experience working with US companies. Here's the idea:

I typically have about 4 interviews per day, which is getting difficult to manage, I'm looking for someone to attend these interviews on my behalf, using my name and resume. If you're interested, this could be a great way for you to increase your income. Here's how it would work:

You would handle the technical interviews (topics could range from .NET, Java, C#, Python, JavaScript, Ruby, Golang, Blockchain, etc).

Don't worry about the questions; I can assist you on how to respond to interviewers effectively. If the interview goes well and we receive an offer, I'll manage the background check process and all other formalities.

After securing the job, you could either work on the project yourself or simply handle the daily standup meetings, as I have a team of 5 experienced developers who can cover the technical work.

As for the pay, we can split the salary, and you can expect to make around \$3000 per month. Let me know if this opportunity interests you.

Or if you know someone in your network who might be interested, please refer them to me, and I'll compensate you for the referral. And then let me explain more details

Best regards, Neyma Diaz

[Link to Calendly]

When you are free, schedule the meeting here, I look forward to hearing from you soon.
Thank you.

Hi, Uannyao? #1







7CodeWizard opened on Jan 27

I have reviewed your github and Linkedin profile, really appreciated at your good skills.
I'd like to offer you an opportunity that I think could be interesting.
I run a US-based job hunting business, and I noticed you have experience working with US companies.
Here's the idea:
I typically have about 4 interviews per day, which is getting difficult to manage. I'm looking for someone to attend these interviews on my behalf, using my name and resume. If you're interested, this could be a great way for you to increase your income.
Here's how it would work:
You would handle the technical interviews (topics could range from .NET, Java, C#, Python, JavaScript, Ruby, Golang, Blockchain etc.).
Don't worry about the questions; I can assist you on how to respond to interviewers effectively.
If the interview goes well and we receive an offer, I'll manage the background check process and all other formalities.
After securing the job, you could either work on the project yourself or simply handle the daily standup meetings, as I have a team of 5 experienced developers who can cover the technical work.
As for the pay, we can split the salary, and you can expect to make around \$3000 per month.
Let me know if this opportunity interests you.
Of if you know someone in your network who might be interested, please refer them to me, and I'll compensate you for the referral.
And then let me explain more details
Best regards,
Neyma Diaz 🍌



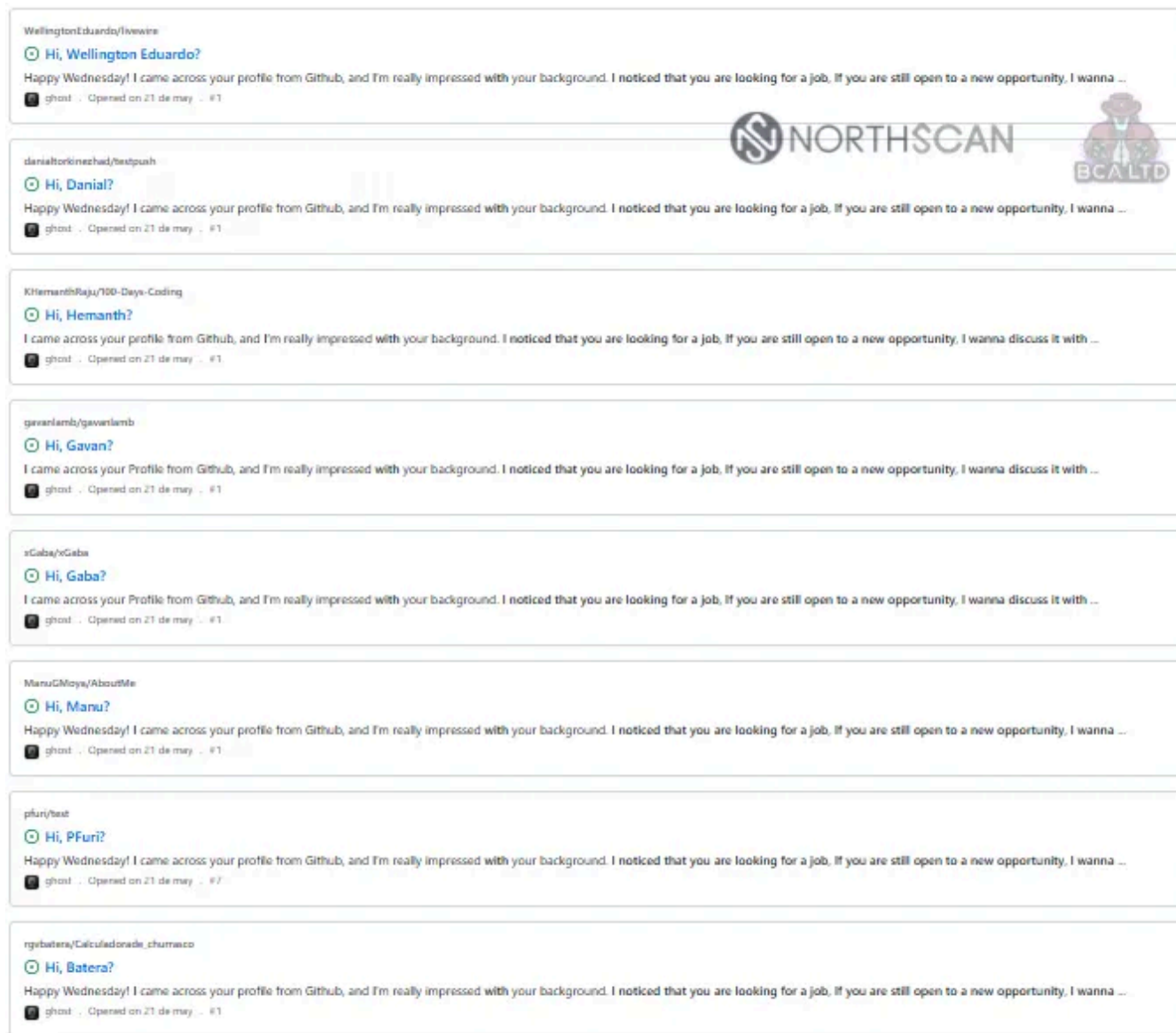
7CodeWizard on Jan 27

Author

<https://calendly.com/7codewizard/30min>
When you are free, schedule the meeting here. I look forward to hearing from you soon. Thank you.



This generic message was **publicly** sent to dozens of developers as **pull requests** on their own repositories, which could be easily listed by browsing the spammer's account or by searching GitHub globally for a couple of the strings contained in it.



Since the spam seemed **massive rather than targeted** (unlike spear-phishing efforts), I inferred that traceability of the contacted profiles would be poor or non-existent. So, the next step was to **impersonate** one of the previously contacted individuals. The lucky draw was a developer named **Andy Jones**.

To replicate him, a new profile account was created, closely resembling the one used by the legitimate GitHub profile. I reviewed Andy's public repositories and associated information to ensure consistency during interactions, reinforcing the impression that our account was a U.S.-based developer, making the persona more attractive as a potential recruitment candidate.



✓ You are scheduled

A calendar invitation has been sent to your email address.

[Open Invitation](#)

30 Minute Meeting



7CodeWizard



11:00 - 11:30, Wednesday, May 28, 2025



Bogota, Jamaica, Lima Time



Web conferencing details to follow.

Schedule your own meetings with Calendly for free

Eliminate the back-and-forth emails for finding time.



Sign up with Google



Sign up with Microsoft

[Cookie settings](#)

[Sign up with work email](#)

In the initial meeting, the strategy was to keep the webcam turned off to introduce a mild sense of distrust, simulating natural hesitation. This was followed by a question regarding ethnicity, explicitly asking “*are you a black man?*”.

Aaron S.



A

A

11:14

im trying to schedule one in your calendly

AS

Aaron S.

11:15

<https://calendly.com/7codewizard/30min>

try to schedule using this link



A

A

11:16

30 Minute Meeting

 7Codewizard

 18:30 - 19:00, Tuesday, June 17, 2025

 Central Time - US & Canada

 Web conferencing details to follow.

just did it :)



Is it still necessary for me to turn on my webcam? To be honest, I feel a bit uncomfortable until I get more trust

AS

Aaron S.

11:23

ofc

A

A

11:24

Or maybe I could turn it on and point it somewhere else, but Id rather not show myself yet :)

AS

Aaron S.

11:24

I can't understand why you are worrying abt turning the webcam

perhaps are you a blackman?

A

A

11:24

In reply to [this message](#)

Because last time, you asked me several times

Aaron S.		
	Because last time, you asked me several times	
	im white tho haha	11:24
	latino/white to be exact	11:25
AS	Aaron S.	11:25
	there is no point to turn off your web cam then	
	this makes me feel so bad	11:25
	If you insist this, I am not able to work with you	11:25
A	A	11:27
	In reply to this message	
	i feel like you said if im black but im white so there is no problem	
	In reply to this message	11:28
	Hell naw lets try to keep the conversation and when we gain trust i can turn my video on	
	i just meet you from like one week ago and your asking a lot of stuff , i dont see the issue , internet is a wild place so im trying to be more chill	11:28
	try to understand my position	11:30
AS	Aaron S.	11:40
	where are you based in now?	
	I tried to understand you and make a good collaboration with you	11:41
	I can't understand at all, why you are acting like this.	11:41
	What kind of experiences do u have but your behavior makes me feel so terrible,	11:42
	with this kind of attitude, I cannot make a good progress and result by collaborating with you	11:42
	I don't require a lot of stuff from you	11:42
	I can't get what you are talking about	11:42

On a second call, which lasted approximately 20 minutes, the primary objective was to adopt a naive posture, appearing unaware of the broader context or implications of the interaction.



Aaron, Recruiter for Famous Chollima

This approach encouraged the threat actor to share detailed instructions and elaborate on their intentions regarding the use of the (impersonated) identity. By asking seemingly *innocent* but *targeted* questions, I aimed to extract as much information on the operation as possible while maintaining the illusion of trust and compliance.

We briefly discuss the ICE situation, my visa status, and then he asks for **access to my laptop 24/7** so that “he can work remotely from it.”

[Watch the video on YouTube](#)

He also explains that he will need my **ID, full name, visa status, and address** to apply to interviews on my behalf.

The interviewer then explains that I will handle the interviews myself with his full support, adding that he will help me set up LinkedIn, prepare my CV, and schedule the calls. He offers a **20% cut** if I **act as the frontman**, or **10%** if he only **uses my information and laptop** while he conducts the interviews himself.

He then walks through the payment methods, mentioning bank details and **Payoneer or PayPal accounts**, and asks for my **Social Security Number** for background checks, stressing that having a clean criminal record is “very critical.”

Next, he tells me not to worry about setting up the laptop, as he will download everything he needs himself.

Next, he mentions that I will need to verify all accounts with my documents on various platforms to meet **KYC requirements**, and he asks me to download **AnyDesk**, a popular remote desktop tool.

Watch the video on YouTube

I tell him I also have another laptop he can use, and we go back and forth as he asks me to “remove my background” so he can see the machine more clearly. I refuse, saying my room is messy.

Then, we discuss how to set up my environment to start working straight away. He says he has no preference regarding the operating system.

I apologize for keeping him up late and he replies that “*he works from different time zones, so it's ok*”.

We agree to install AnyDesk so he can walk me through everything step by step.

Watch the video on YouTube

We continue chatting on **Telegram**. The next day he plans to look for jobs with my LinkedIn profile.

He then shares the sectors he's interested in targeting: **IT, fintech, e-commerce, and healthcare**.

AS

Aaron S.
IT, fintech, e-commerce, healthcare companies


09:48

I don't need your personal pictures





09:49

what you have to do is jut to share your linkedin profile and email, other info that I told you, with doc

09:49

make sense?

09:49

it's really hard to work with you




09:49

when I am working with other clients, they gave me all the info that I suggested in a short time

09:50

but I can't understand why it's difficult for you

09:50

I want you to let me know till when you can share all the details

09:55

A

In reply to [this message](#)

09:59

hey dont be hard to me, im really dumb into this job searching stuff and sometimes i get scared but give me opportunity tho

In reply to [this message](#)

09:59

Ok ok, hold on

AS

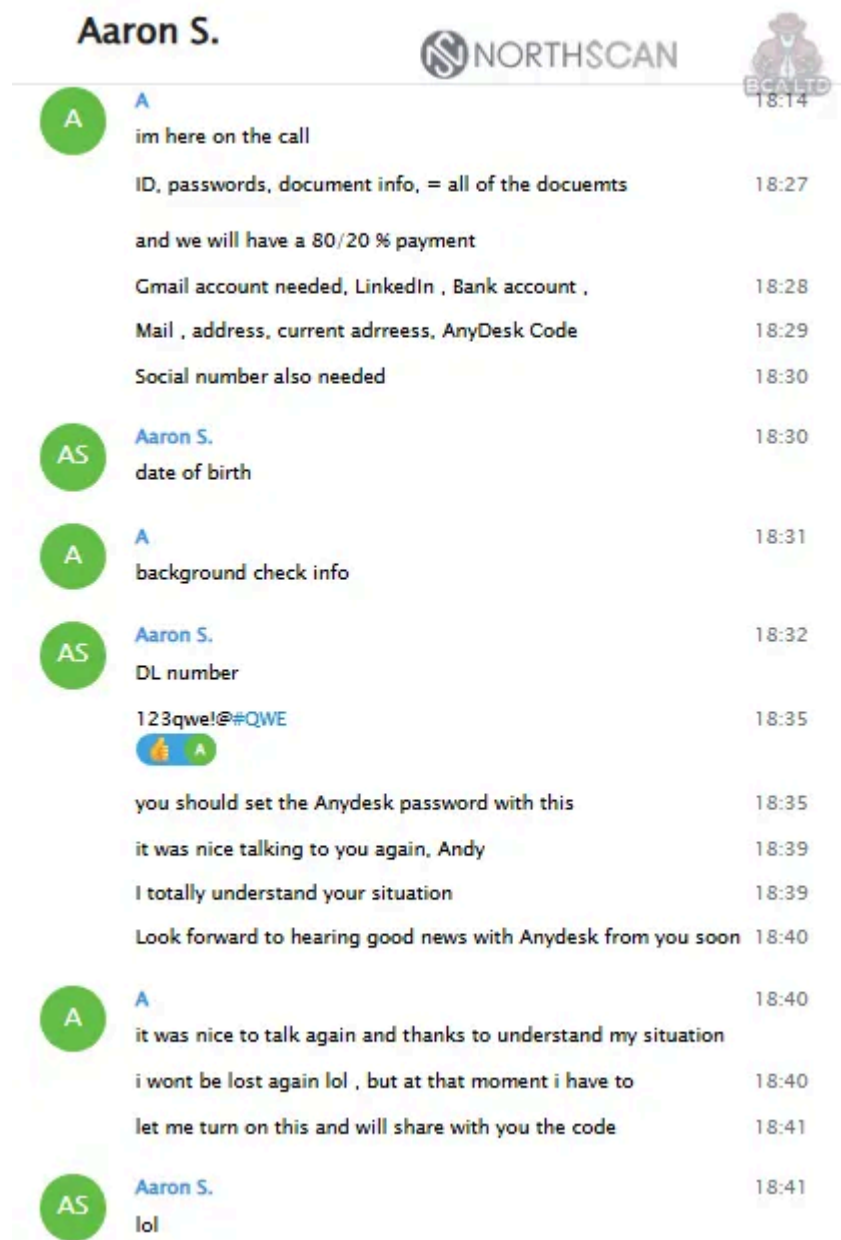
Aaron S.
what you have to do is just sharing your info
and I will do all other things to secure info,
you should support me well to secure an offer




Then I will pay you for supporting me

10:00
10:00
10:00
10:00

Later that day, we do a final review of our terms, agreeing that I will receive a **20% cut** and share access to Gmail, LinkedIn, bank accounts, my SSN, and any background-check information. After that, he asks me to set “123qwe!#QWE” as the password for AnyDesk.



I took some time off while Mauro and ANY.RUN set up the farm, so I had to come up with an excuse. In a follow-up meeting, Aaron tells me not to disappear and to stay in touch on Telegram, saying that **communication is important** and that he wants to be connected to me 24/7. He again asks me to set a specific password on AnyDesk and keep the machine available around the clock. I tell him I will and jokingly ask him not to peek at my photos. We share a laugh, and he assures me he won't do anything outside "his work."

Watch the video on YouTube

Then, I allow him to connect to my "laptop."

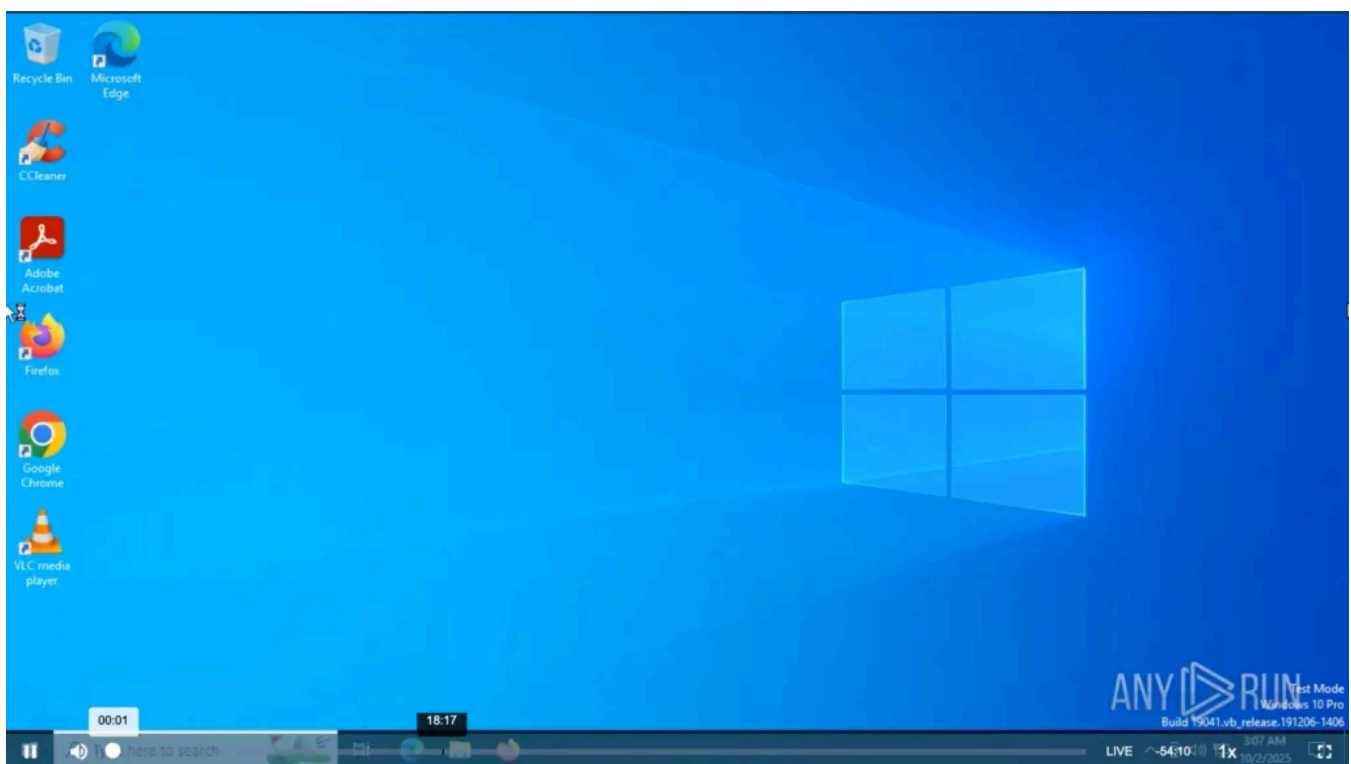
Chapter II: The Farm

Trapping Famous Chollima | Mauro Eldritch (BCA LTD), ANY.RUN

We never had spare laptops for them. **It was a bluff** to earn their trust. In fact, our plan was to force them into a **controlled environment**, a sandbox, so we could monitor everything they did in real time.

Our obvious choice was ANY.RUN's malware sandbox, which we had already used to analyze previous DPRK samples (**QRLog**, **Docks**, **InvisibleFerret**, **BeaverTail**, **OtterCookie**, **ChaoticCapybara**, and **PyLangGhostRAT**).

But there was one limitation: the standard sandbox sessions were not designed to run for more than about half an hour; enough for malware analysis, but not enough to convince state-sponsored operators that they were using a real machine.



A normal ANY.RUN instance

While this could have been an obstacle, we reached out to ANY.RUN, and they arranged extended-runtime instances for us.

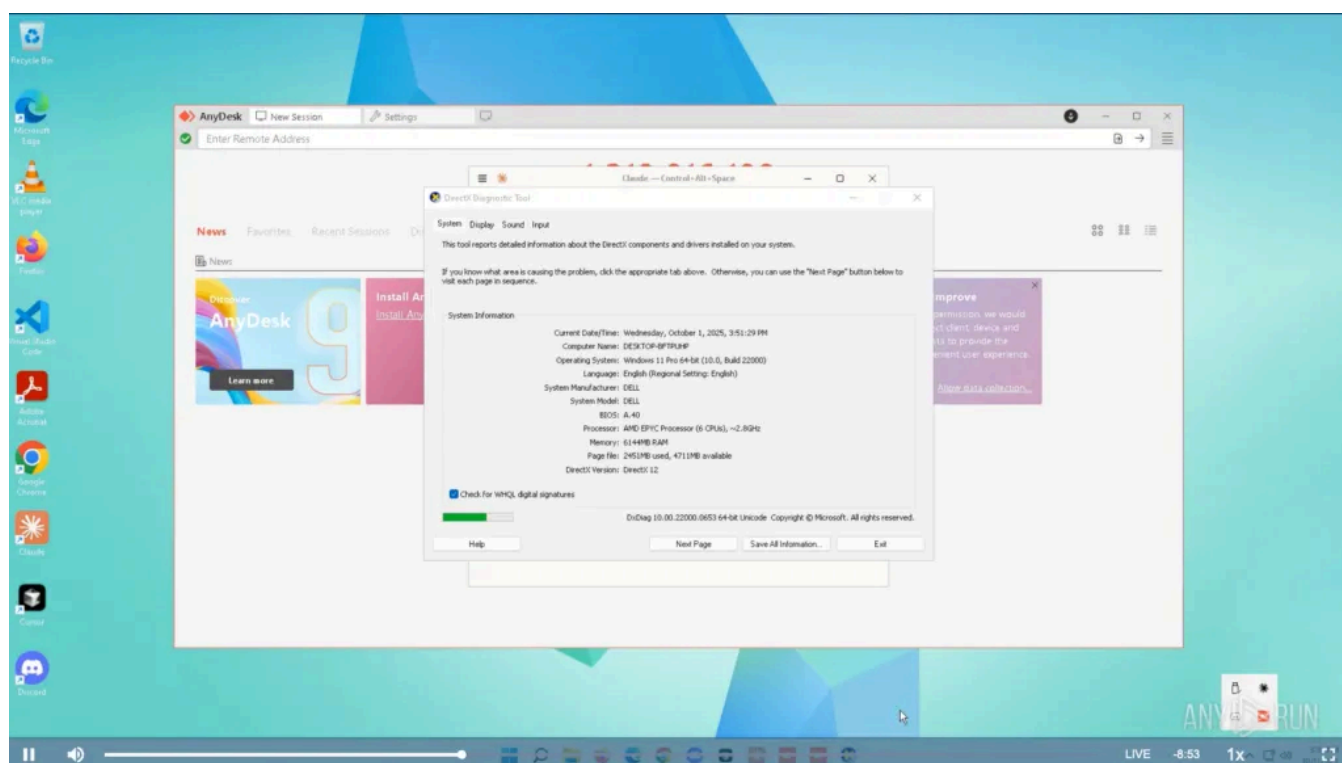
Detect phishing threats in under 60 seconds

Integrate ANY.RUN's Sandbox in your SOC

[Sign up now](#)

In an unprecedented effort, and delivered in record time, they provided a **special version of the sandbox** that could run for hours, complete with **pre-installed**

development tools and a realistic usage history to mimic a laptop actively used by a real developer.



Our special ANY.RUN instance

This setup was enough to trap the Chollimas inside and extract as much information as possible; from the files they opened, downloaded, or modified, to their network activity (including their IP addresses and contacted servers), to every single click they made. Everything was broadcast and recorded in real time for us to observe.

It was time to open the farm and let them in.

Chapter III: The Watchers

Spying on Famous Chollima | Mauro Eldritch (BCA LTD), ANY.RUN, Heiner García (NorthScan)

For this experiment we instantiated multiple **sandboxed environments**; some featuring a normal **Windows 10** with basic apps and config, and another one with **Windows 11** and **pre-installed userland** to make it look like a real developer's personal laptop.

The environments were routed through a residential proxy to create the appearance of being located in the **United States**, matching the threat actors' preference for U.S.-based developers.

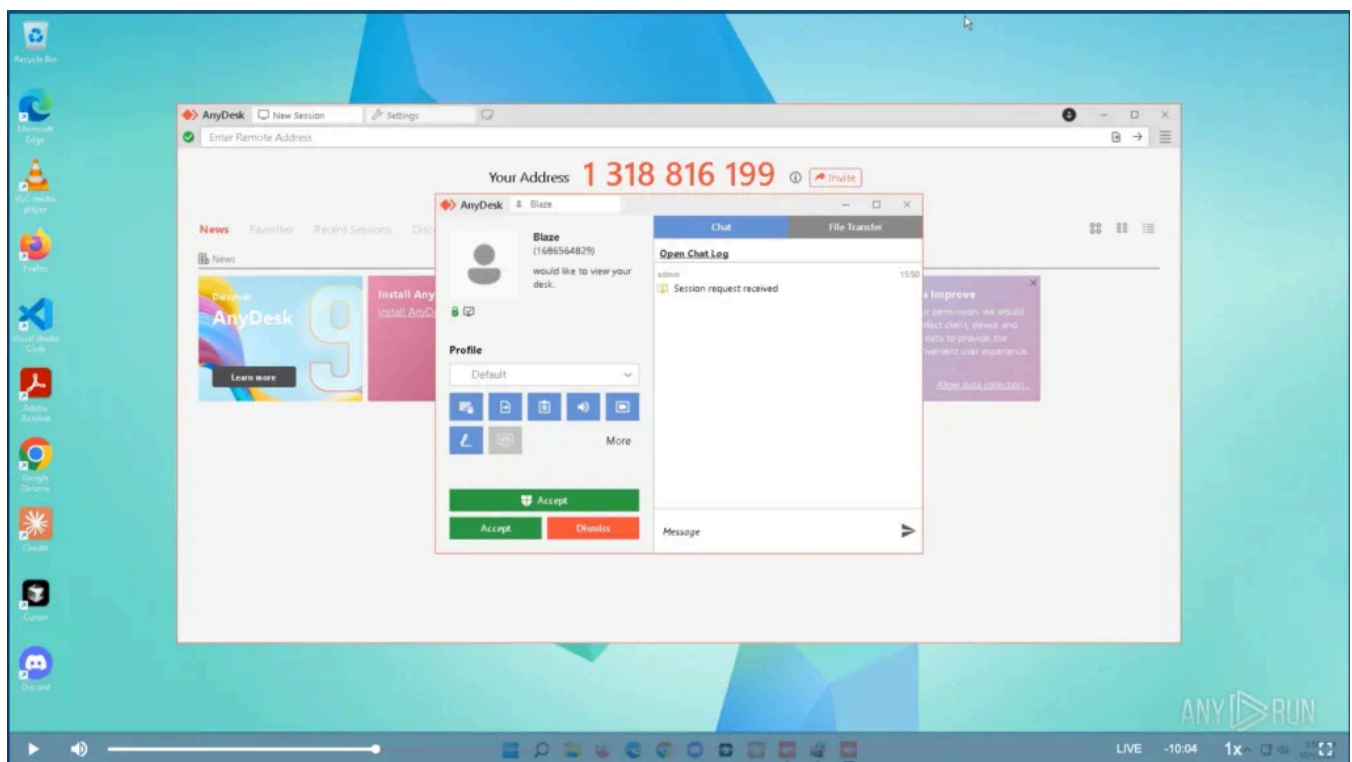
In addition, we could monitor their **screen, network, and file system activity in real time** without them noticing, and we had **full control** over the machines at any moment. This allowed us to disconnect them from the internet while keeping their remote desktop session active (simply blocking their ability to browse) or even force-shutdown the machines to prevent them from carrying out any real malicious activity against third parties.

We divided these recordings into “**tapes**” to make it easier to appreciate their behaviour.

Tape 1: The Planning

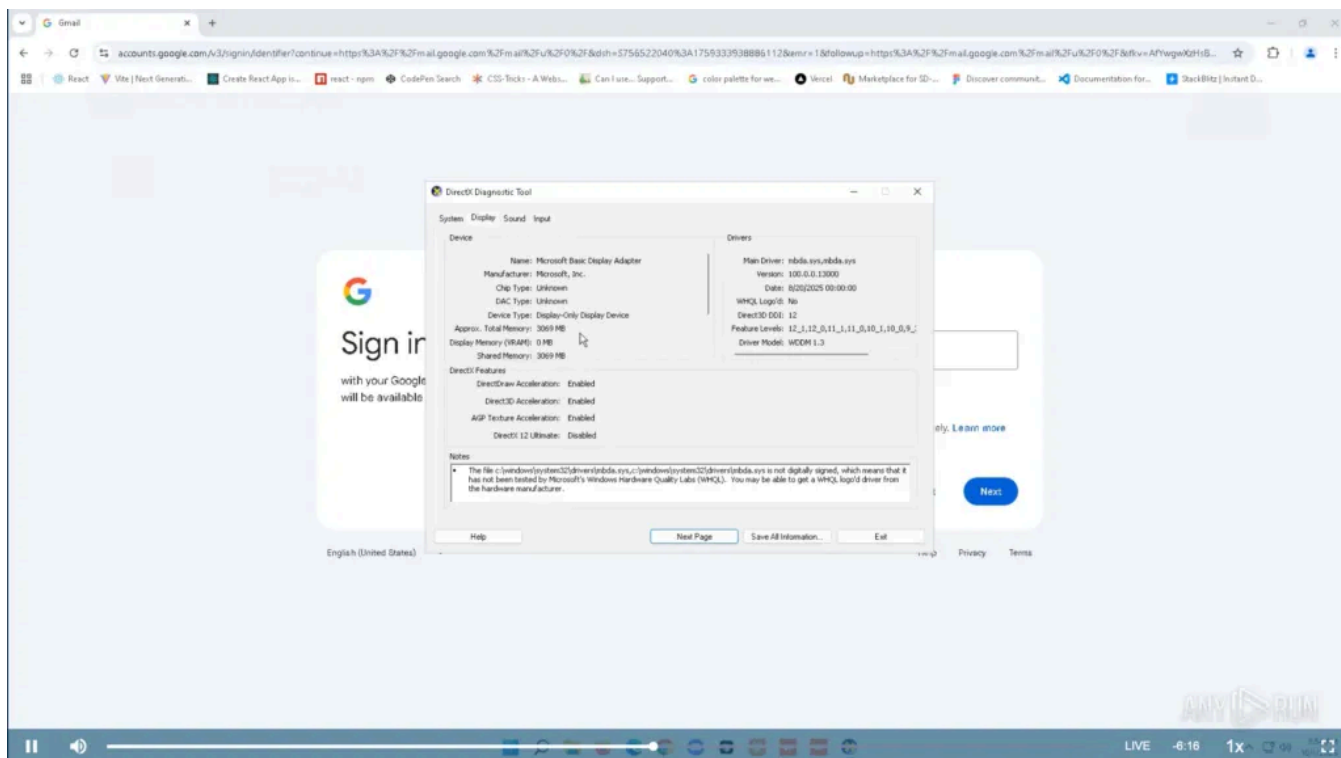
Note: Some tapes have been edited for brevity, removing periods of inactivity.

We set up the **initial laptop** (Windows 11) following the instructions received from the recruiter and setting the password designated by him. A few minutes later, “**Blaze**” (Aaron, our recruiter) connects via **AnyDesk** and starts **scouting the machine**.



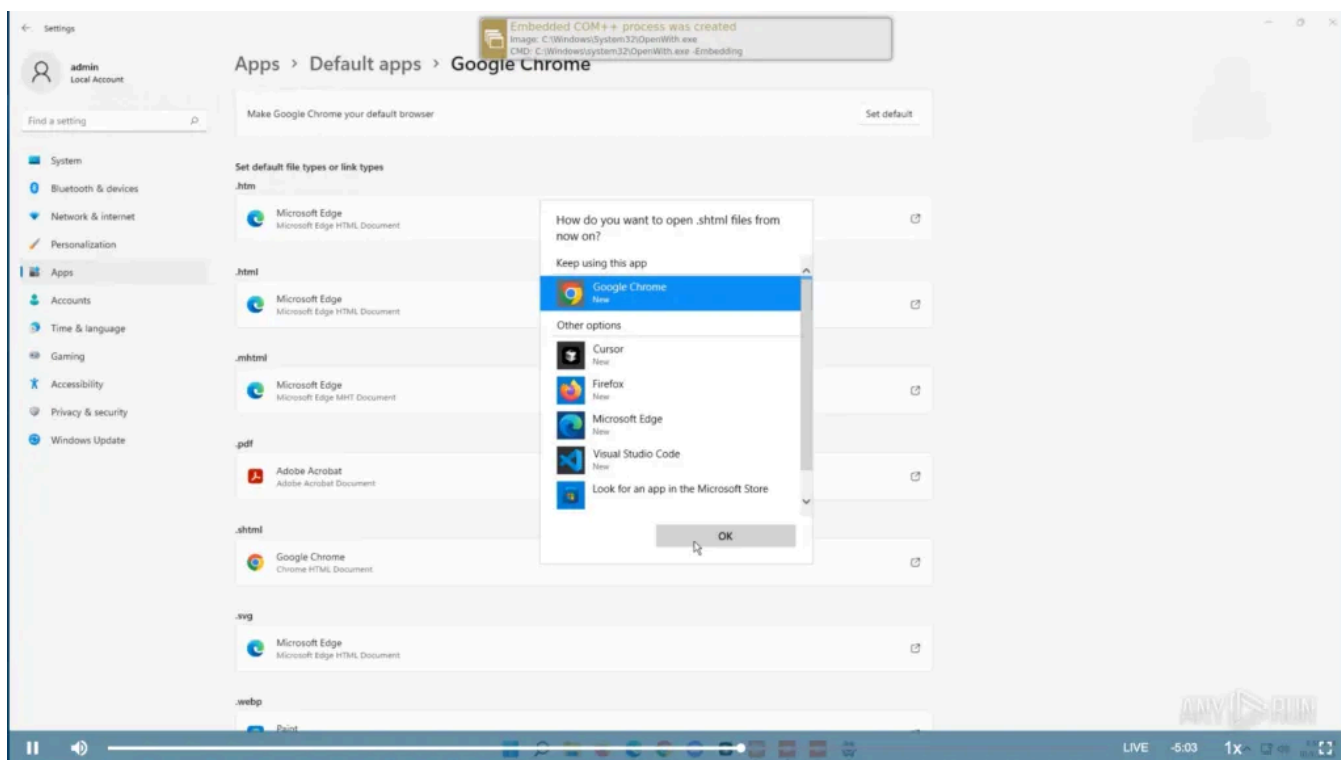
Blaze connects to our “laptop”

The first thing he does is run **DxDiag** (DirectX Diagnostic Tool) to get a **full report on the machine's hardware**. Having foreseen this possibility, the machine presented standard hardware and drivers from well-known manufacturers, **mimicking real pieces** commonly found in most home setups and laptops.



DxDiag showing common drivers and devices

Next, he opened **Google Chrome** and visited the **Gmail** website. He went back to **DxDiag** and browsed through the different tabs, scouting the machine's configuration, and then he set **Chrome** as the default browser.



Blaze sets Google Chrome as default browser

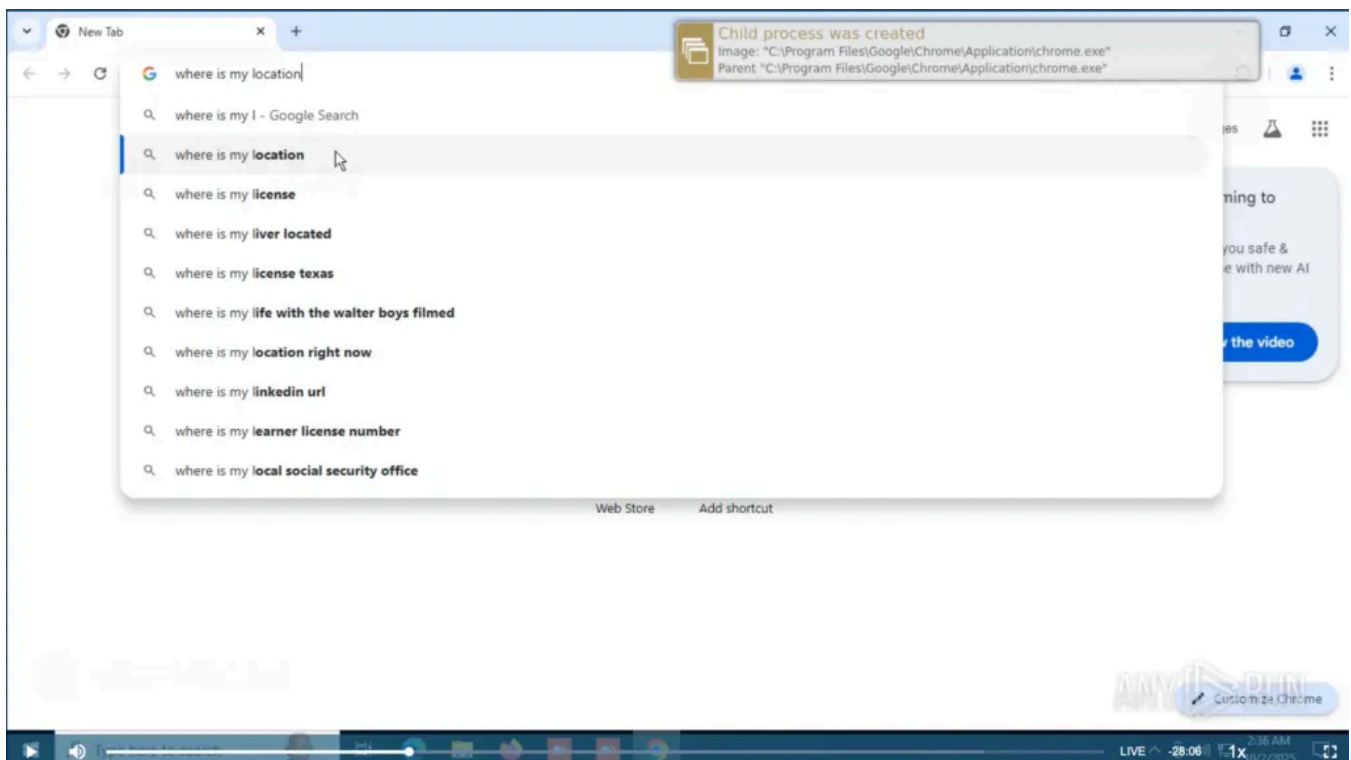
Finally, he opened **Visual Studio**, played around and searched online for “*where is my location*” (sic).

He was met with some **CAPTCHAs**. While he was busy sorting buses and staircases we started monitoring his network activity.

He was connected from an IP address located in the **United Kingdom**.

According to OTX (United States for most scanners) belonging to **Astrill VPN**, one of the North Korean threat actors' favourite tools.

Then, we decided it was time to crash the machine.



Blaze searches "where is my location"

These crashes were **intentional**, both to prevent him from engaging in malicious activities and to **delay his actions**.

The system remained unavailable until we manually started AnyDesk once again, and after every "recovery" we convinced him that a System Restore was needed, thus **reversing any progress he made**. This tactic helped us keep him in the loop for weeks.

[Watch the video on YouTube](#)

Tape 2: A Note for Andy

After the instance "crashed" we had an excuse to switch him to another "laptop", this time running Windows 10, **setting back all his progress**. He started the same dance,

changing his default browser to Chrome and looking up “*where is my location*”.

Google started acting up, putting him into a **never-ending CAPTCHA loop** which he stoically endured, solving them patiently. He then opened a **command line interpreter** and ran the command “*whoami*”, which returned the username “*admin*”, and “*systeminfo*”. The latter returned **consistent information regarding system hardware and software**.

He trusted the system and opened a **Notepad** window, where he left a **note for “Andy”** (Heiner’s alter ego):

Hi, Andy?

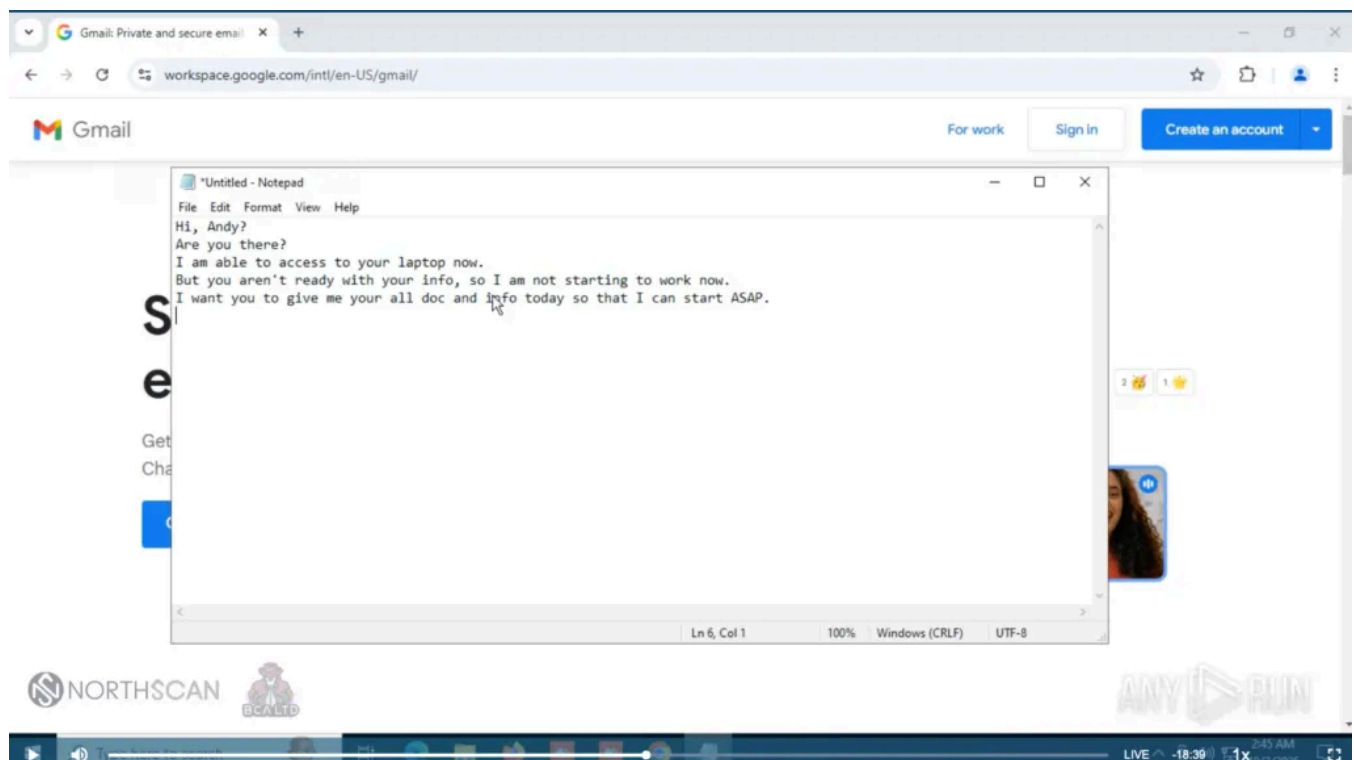
Are you there?

I am able to access to your laptop now.

But you aren’t ready with your info, so I am not starting to work now.

I want you to give me your all doc and info today so that I can start ASAP.

And now, could you possibly log in your email and linkedin here in laptop?



Blaze’s note for Andy

We left him **waiting** to test his patience. He didn't insist, and we proceeded to crash this "laptop" as well; to make him believe we were not able to catch his message and **delay him** further.

Every minute spent with us was one less minute scamming someone else.

[Watch the video on YouTube](#)

Tape 3: Incorrect Password

Another crash, another jump into an **old system recovery point**, which **erased all his progress**. We started **putting pressure on him**, asking what he was doing that crashed the system beyond repair, stating that a **Blue Screen of Death** appeared showing something **related to the network**, probably a misconfiguration or **weird VPN usage on his side**.

He couldn't respond satisfactorily to any of these claims and tried once again to log into the accounts. We provided **incomplete information**, trapping him in a **login and CAPTCHA loop** that lasted for almost an hour, while we extracted indicators of compromise and behavioral patterns.

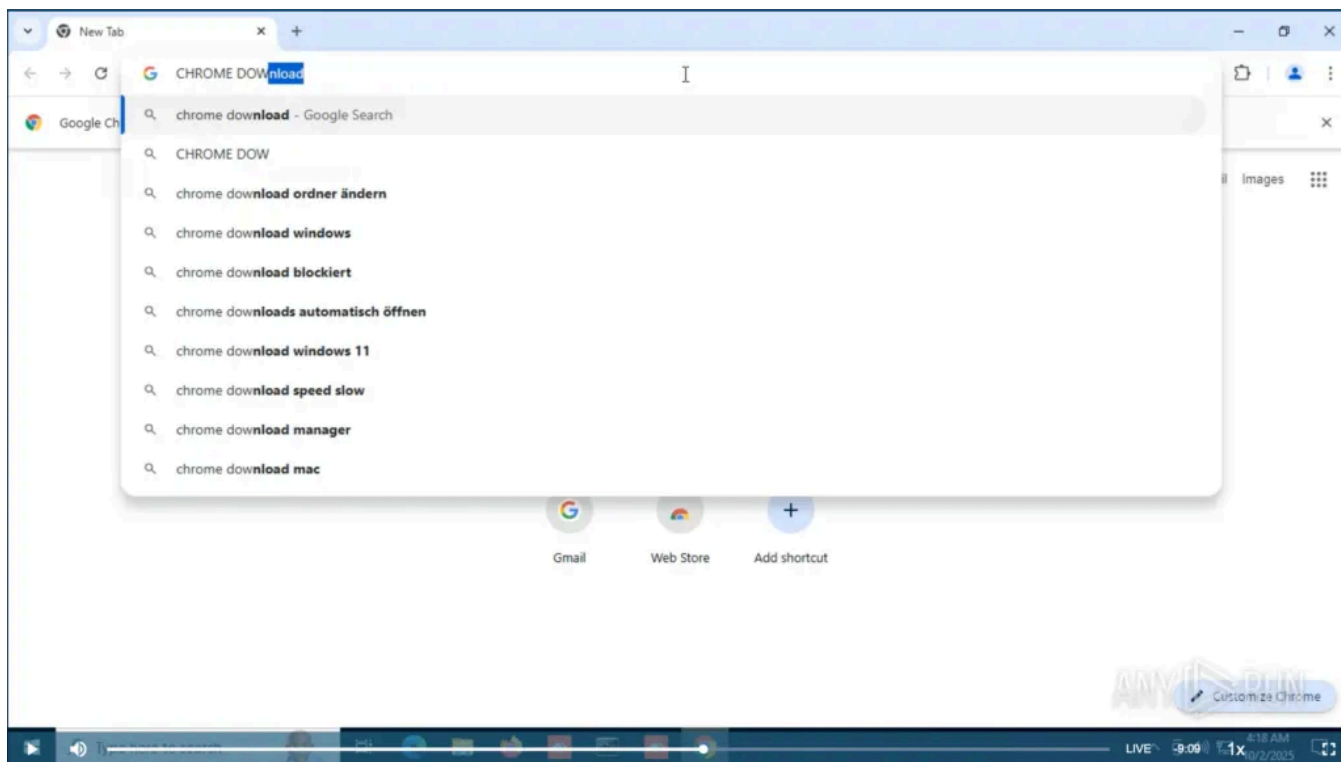
[Watch the video on YouTube](#)

Tape 4: Intruder

This time there was no crash involved and as a gesture of goodwill we built an **autofix BAT script** that would **recover the workstation automatically** if something occurred. We asked Blaze to be careful and gave him a sort of **ultimatum to stop breaking our laptops** and to **start working ASAP**, or the deal was done, putting more pressure on him.

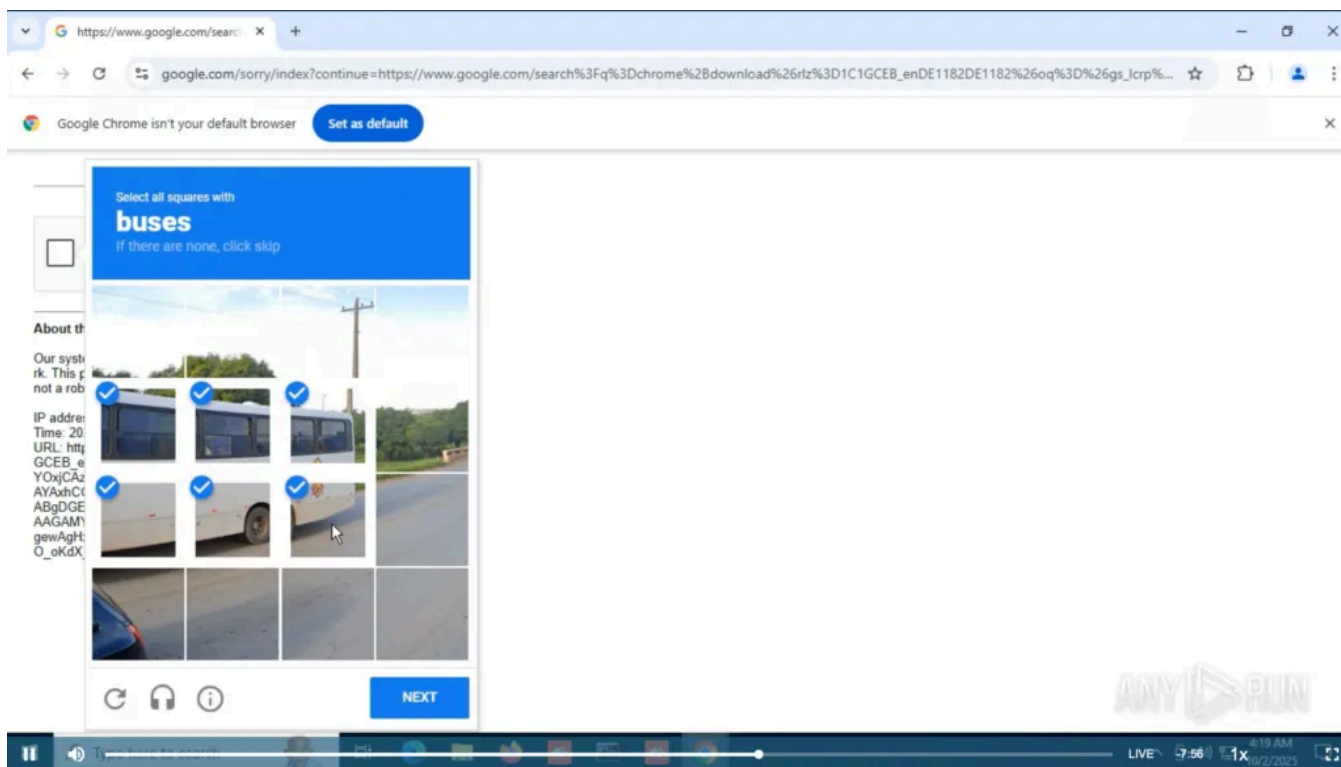
This seemed to strike a nerve, **as another AnyDesk account** by the name "**Assassin**", unknown to us at the time, **logged into the laptop**. It went straight to Gmail and attempted to enter Andy's account, even clicking on the "*Show password*" checkbox to verify the entered credentials. After failing to do so multiple times, **Blaze himself remoted into the laptop**. We believe he tried to offload the task to **another affiliate** who was (somehow) less savvy than him.

He then proceeded to check the system settings and opened **Chrome**, searching for "*Chrome Download*", like a senior person opening the **Google** app to search for "*Google*".



Blaze using Chrome to search for Google Chrome

Without him noticing, we **removed the residential proxy** and **connected the machines through a German VPN server**, so his Google search fell once again into a **CAPTCHA hell**, being forced to solve at least six multiple-choice challenges before proceeding.



Blaze solving CAPTCHA challenges

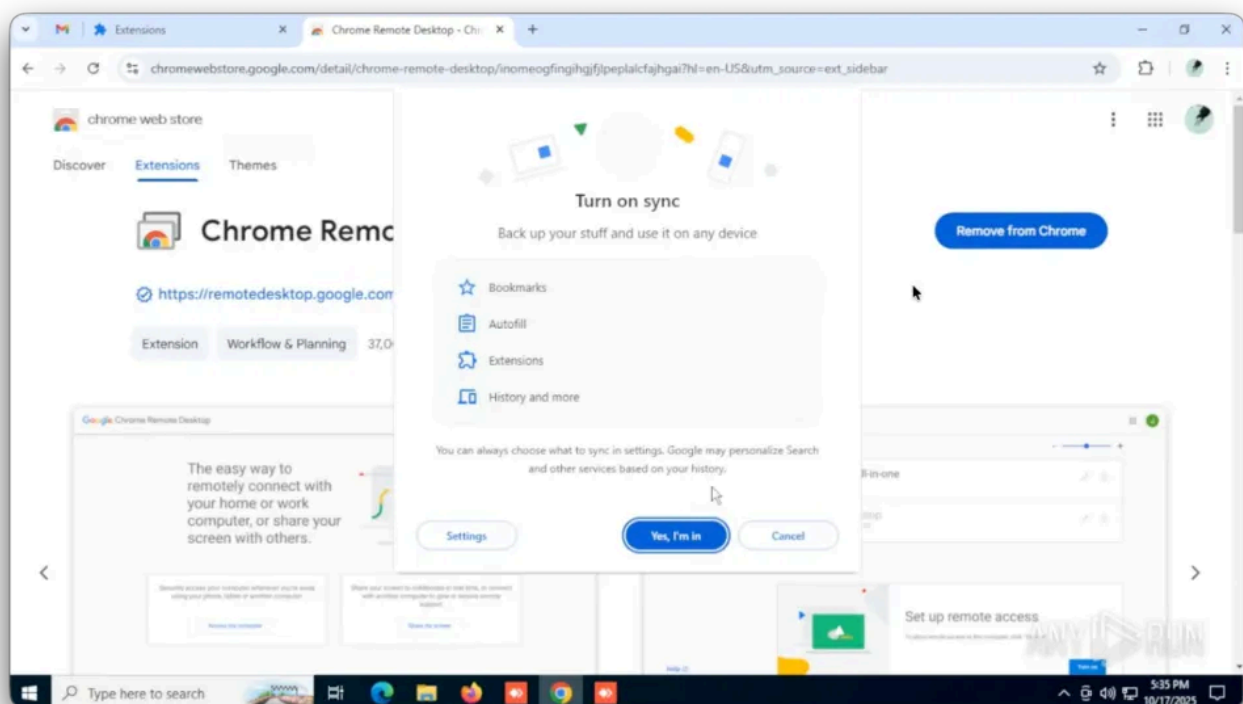
Once he was greeted by the German version of Google he asked us what happened. We told him that to **avoid the BSOD** caused by something faulty in the network, **we were trying a VPN “at router level”**. He complained, saying that *“it’s not optimal”* and *“should be fixed”*, but regardless, decided to continue.

He searched for *“where is my location”* and *“where is my ip”* after finally jumping into **LinkedIn**. Well... the German version of LinkedIn. He tried the account and left it there.

[Watch the video on YouTube](#)

Tape 5: Criminal Engineering

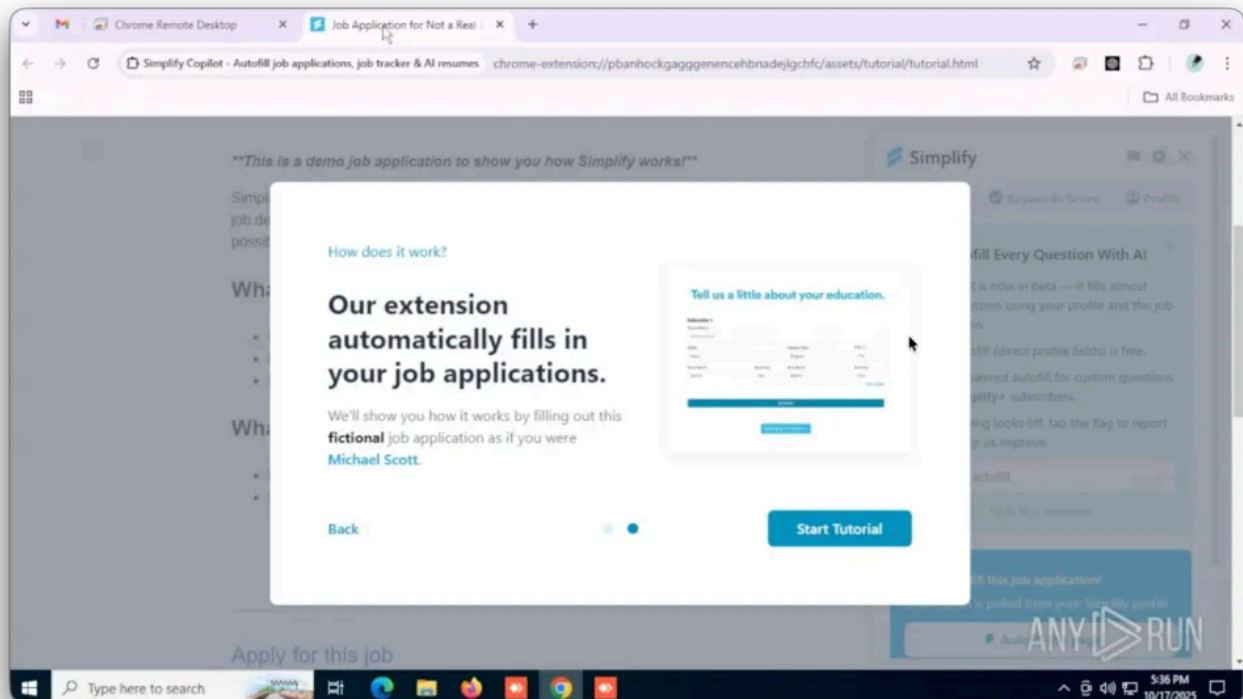
This time it works. Blaze connected to the laptop and logged into **his Google account, “Aaron S”**, turning on the **sync function** and loading his profile, preferences and extensions into the browser.



Blaze turns on the sync function on Chrome

This granted us a first peek into the **Famous Chollima toolset**, which includes **multiple AI tools** like **Simplify Copilot** (to autofill job applications), **AiApply** (to automate job seeking), **Final Round AI** (which provides answers for your interview questions in real time) and **Saved Prompts for GPT** (to bookmark LLM prompts), the

OTP.ee extension (or Authenticator.cc, an OTP generator) and last but not least, Google Remote Desktop.



Simplify Copilot extension installed

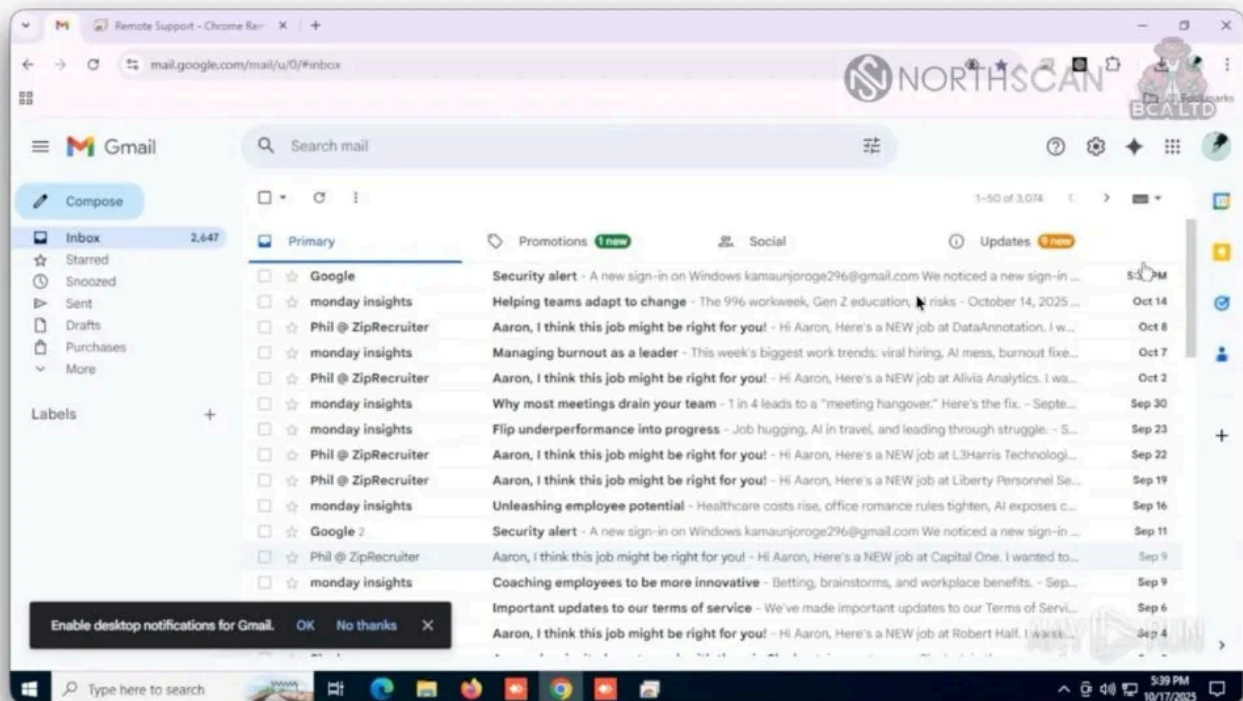
Next, he opened **Google Remote Desktop**. With his account already displaying two other hosts, “AARON-PC” and “Blaze“, he started setting up this laptop via **command line interface** and **PowerShell**, putting “123456” as its **connection PIN**. Meanwhile, he checked his email account.

Without any doubt, we understood it was the proper time for an **unexpected crash**. He was **kicked** from the laptop and we were left alone with his email account open.

[Watch the video on YouTube](#)

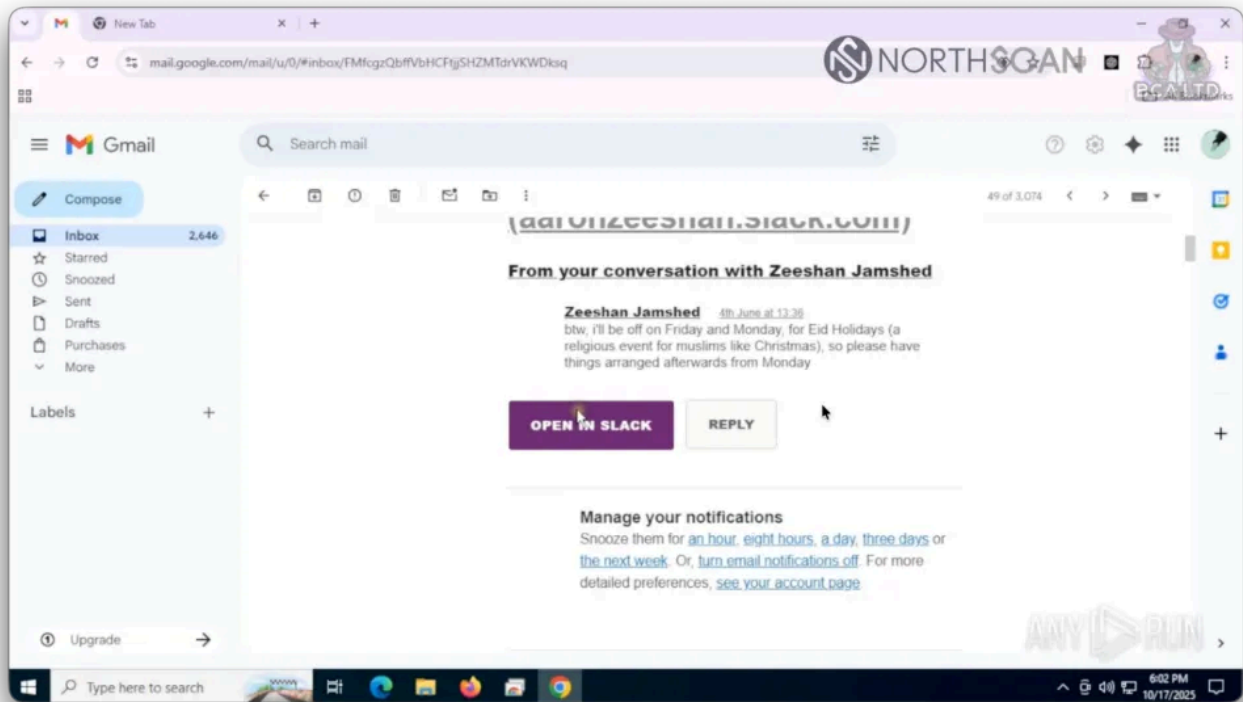
Tape 6: Eavesdropper

Blaze sent a **Telegram** message saying that “*he left his email account open*” and asked to **please close it**. Andy (Heiner) replied that it was already late and he would do it next morning.



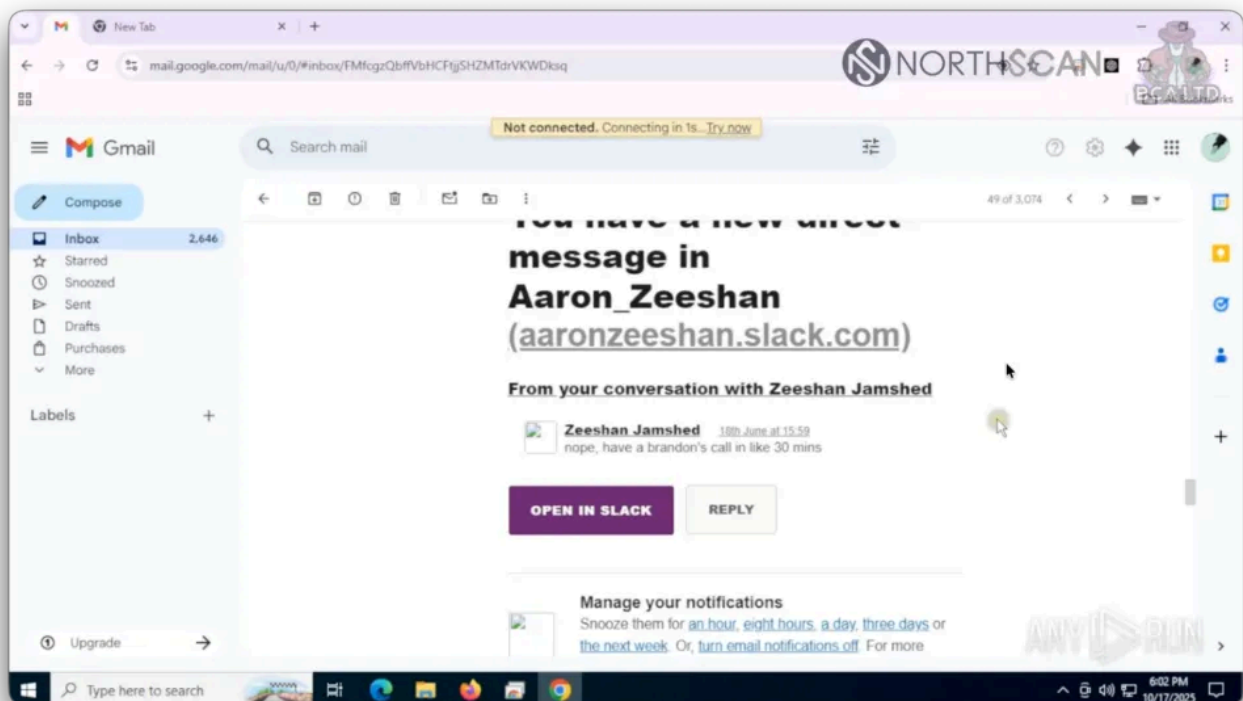
Blaze's email account

We remained offline, checking his email to avoid him remotely ending the session, finding multiple subscriptions to job-seeking platforms, peeking at his extensions and finding different Slack workspaces and chats. He spoke regularly with an individual named Zeeshan Jamshed, who in an initial conversation stated that he would be out for *Eid*, the Muslim festivity, and “to have everything arranged by Monday“, suggesting they were already working together, possibly at a company based in a Muslim-majority region.



A conversation with Zeeshan Jamshed

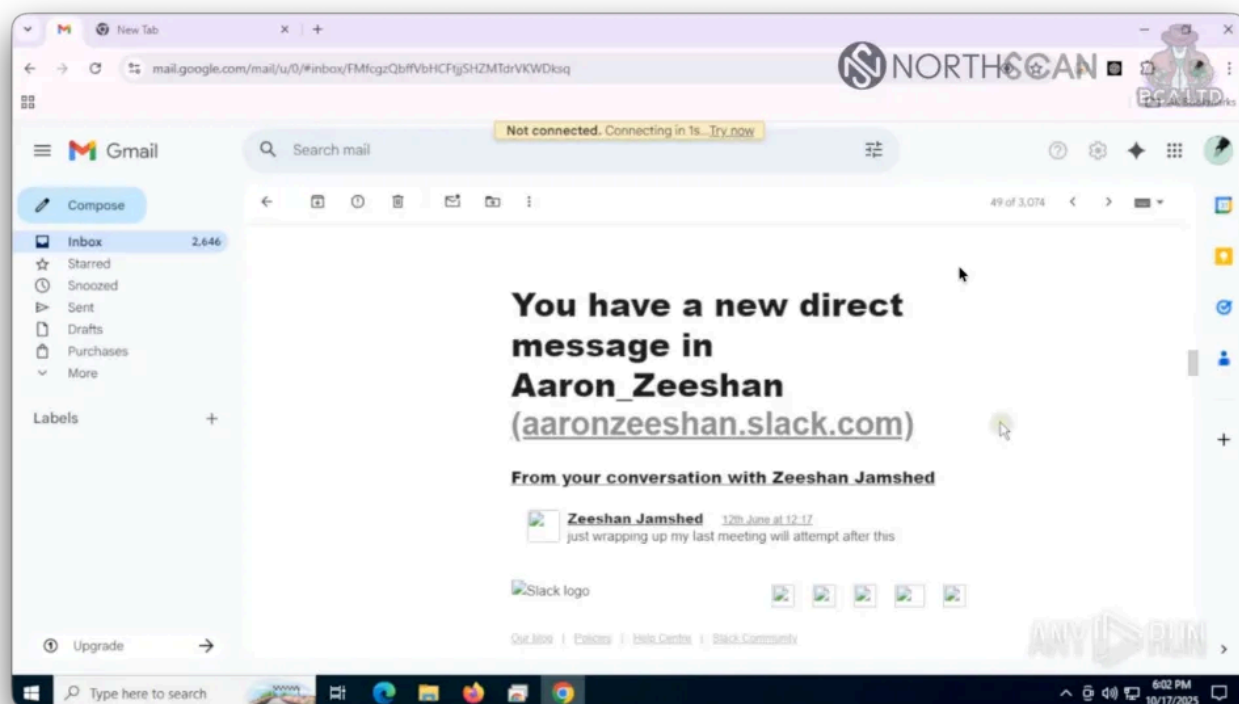
As the conversations continued, the tone turned bitter.



Another casual conversation with Zeeshan

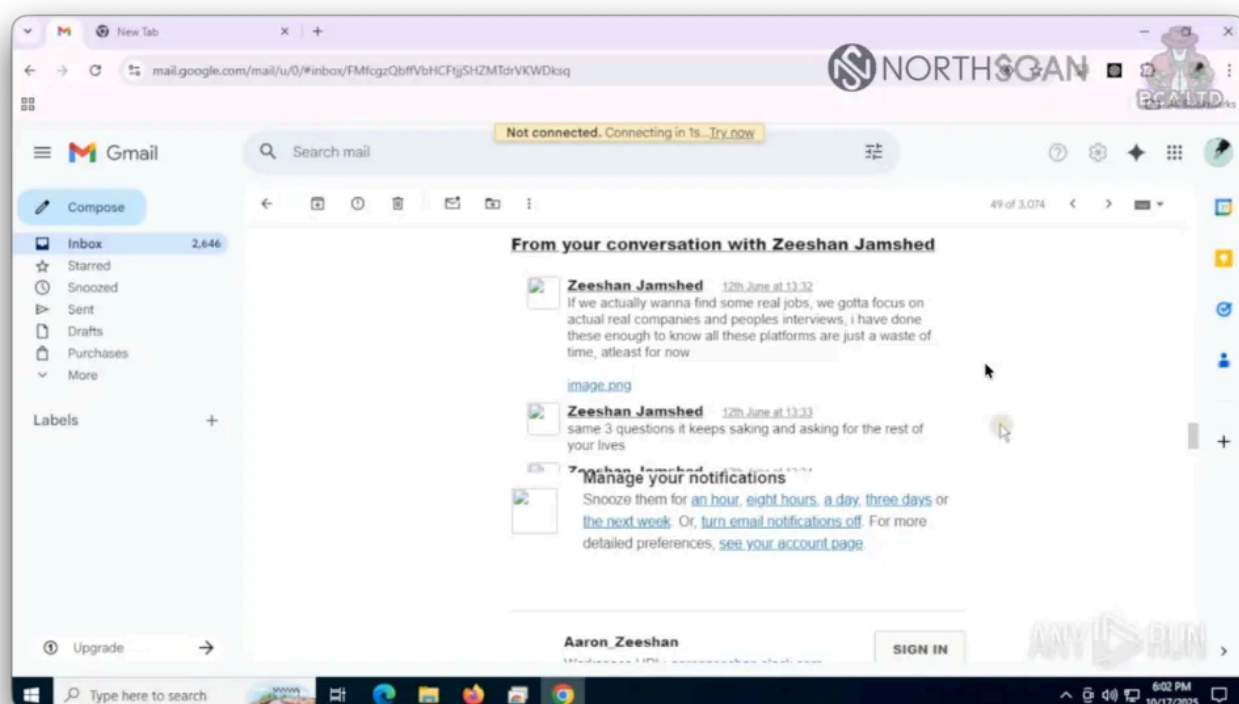
First, Zeeshan mentioned routine things like having to make a call in a few minutes or wrapping up another meeting soon, but then he seemed to crack under his

current reality.



Zeeshan comments on wrapping a meeting

Suddenly **Zeeshan** stated if they wanted to find “*some real jobs*” they had to focus on “*actual real companies and people’s interviews*“, and that he “*has done these [interviews] enough to know all these platforms are just a waste of time*“.



Zeeshan rants about job seeking platforms

He ended his rant talking about the “*same 3 questions that keeps asking and asking for the rest of your lives*“. Whatever that could mean, it seemed to be something that kept him awake.

[Watch the video on YouTube](#)

Tape 7: Fool me Twice

We told **Blaze** the **Windows 11** laptop was repaired and ready to be used, so he was happy to hop on and **log into all his accounts once again**.

After setting up his account again (and **turning on the sync options** reinstalling his extensions), he proceeded with his well-known waltz: search for his **location** (this time correctly pinned in **Texas, United States**), setting up **Google Remote Desktop**, checking his **email** (without noticing anything odd after our inspection), and facing **unrecoverable problems artificially caused by us**.

We messed with the residential proxy and suddenly he was **offline**, without any chance of connecting to the internet. He started troubleshooting his way through the classic steps: reviewing the **internet adapter** configuration, messing with the **authentication settings**, and even **turning off IPv4 completely**. Never for a split second did he stop thinking *why* he was still remotely connected to an isolated system without facing any issues.

He tried to reach the **Google logout button** but he was already offline.

And when it rains, it pours. What else could happen now?

Of course, an **artificial crash**.

[Watch the video on YouTube](#)

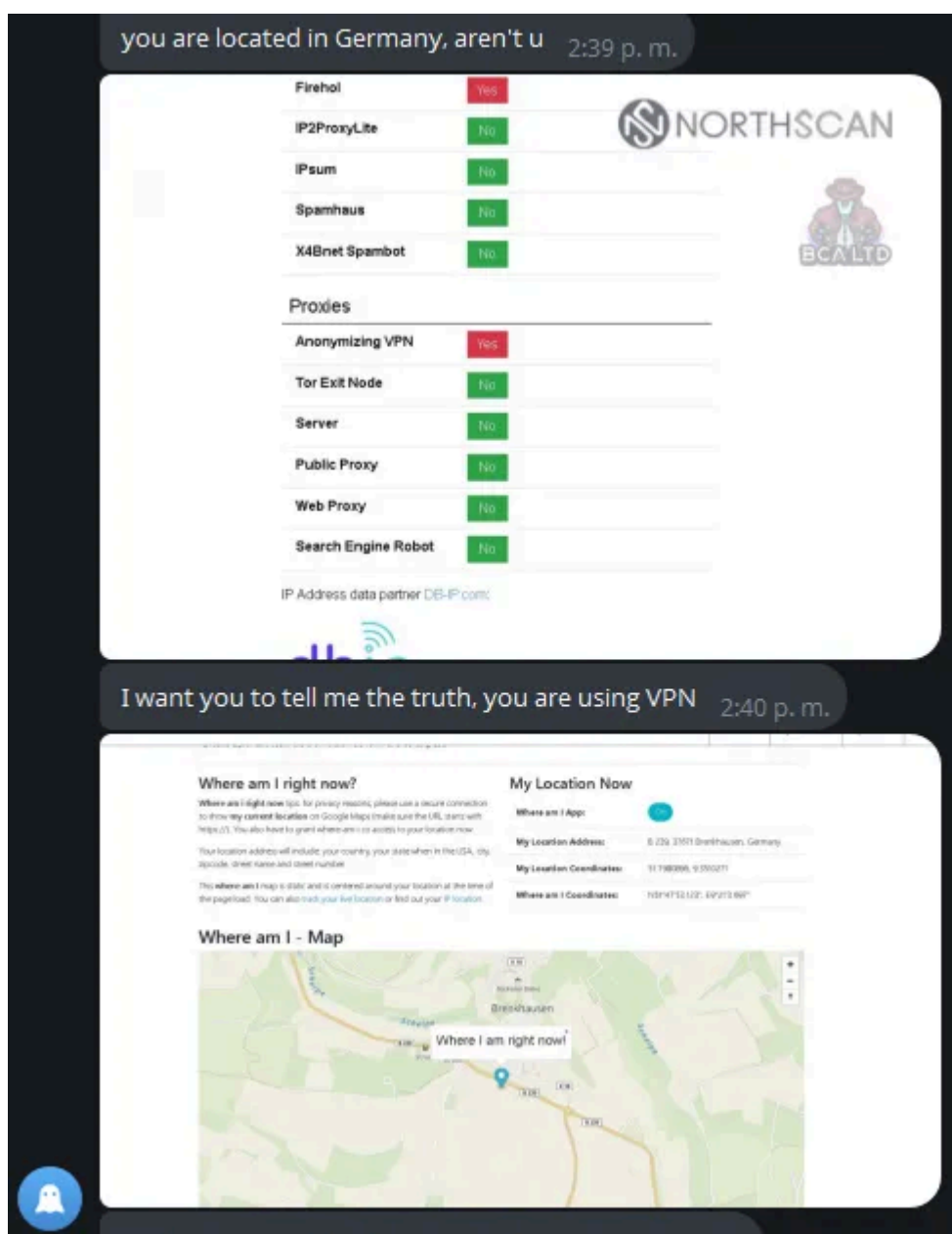
Tape 8: Realization

Blaze asked for explanations regarding the machine's constant malfunctions and even **grew brave enough to escalate his wording**. We made up some excuses and granted him access one last time. This time, we **disabled the proxy** and allowed his slow-paced mind to catch up with the events.

Suddenly, realization hit. And sooner rather than later, the realization became desperation: he knew what was going on.

He opened the **Windows Registry** and started looking online for his location, now appearing in **Germany**. He ran **DxDiag** once again, just like when we started this “collaboration”, and started looking for his **IP reputation** online using search terms like “*ip fraud check*“, and visiting sites like **IP Score**, **Scamalytics**, and **Where Am I**.

He tried to confront us via **Telegram**, but it was already too late. There was no reason to keep playing, so we ignored him.



Famous last words

Paranoia got the best of him, and he ran the **systeminfo** command once again, played around with **DxDiag** a little bit more and then... one last artificial crash,

ending both the instance and our friend's corporate espionage plot.

[Watch the video on YouTube](#)

Bonus Chapter: The Jealous

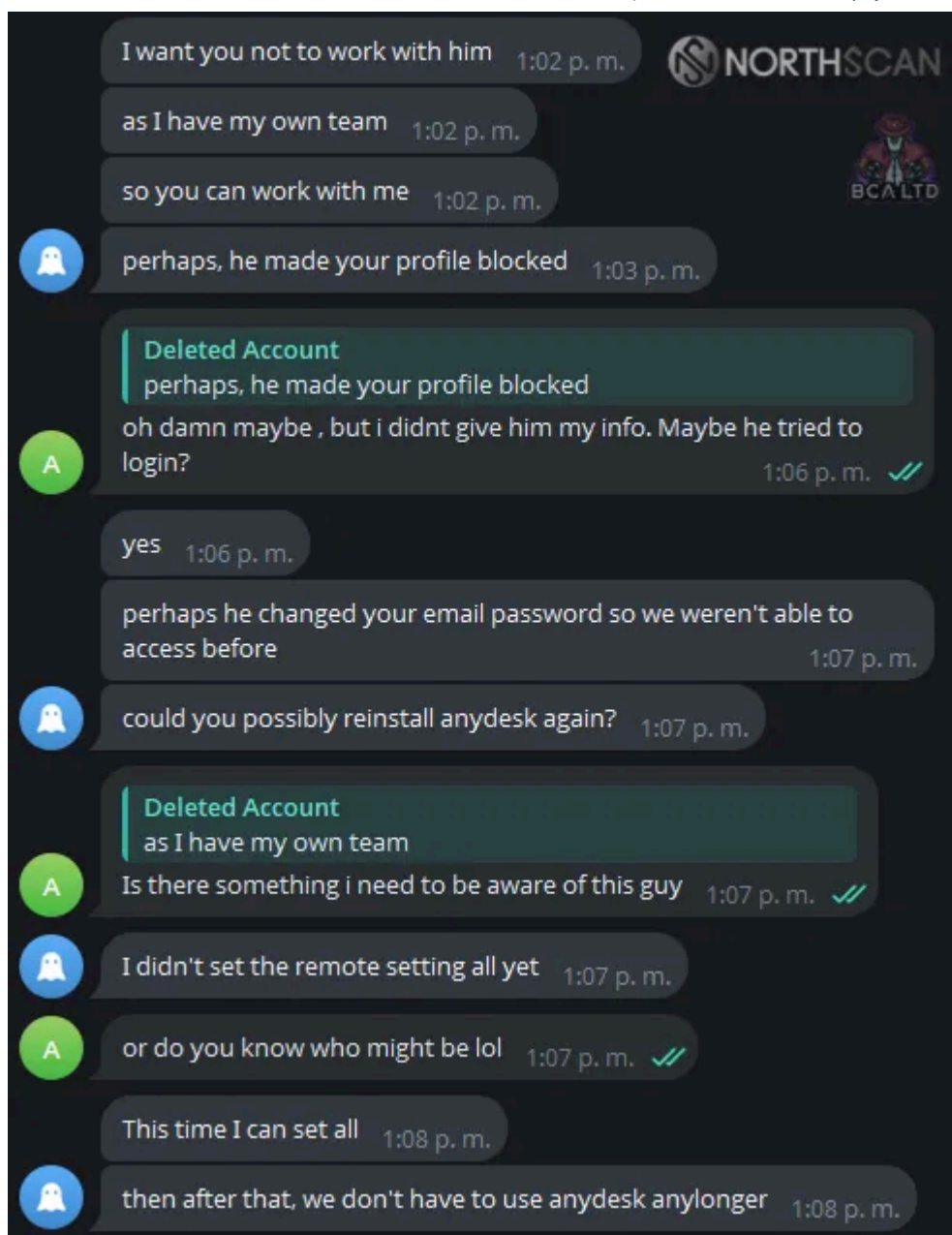
Turning Famous Chollima against each other | Heiner García (NorthScan)

You may probably remember from “**Tape 4 — Intruder**” that *someone else* accessed one of our laptops, one of **Blaze**'s collaborators under the nickname “**Assassin**”. Both had trouble logging into the account and ended up wasting time in a **CAPTCHA hell**.

By that time, we had given **Blaze** an **ultimatum**: **start working now, stop breaking things**. But that's just a part of the story.

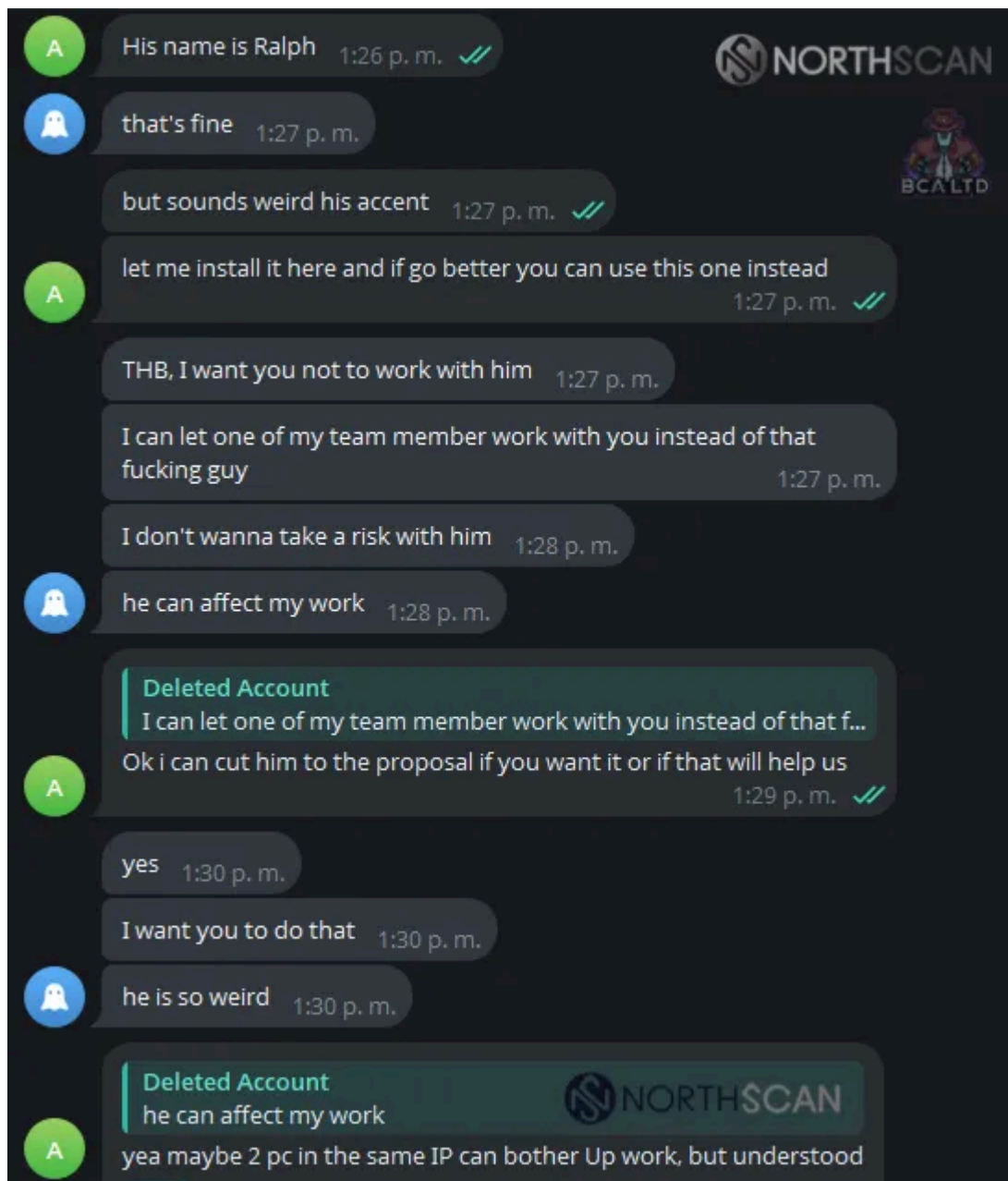
Aiming to put pressure on him, **Heiner** came up with the idea of pretending to be scouted by **another DPRK recruiter** named “**Ralph**”. He reached out to **Blaze** to tell him that aside from our given conditions, he should be cautious because we already had a **better offer for a bigger salary cut** with someone who actually seemed excited to work with us and wouldn't give us as much trouble.

He didn't take it well, asking **Heiner** not to work with him, suggesting that “he” (**Ralph**) could be the one who “*blocked*” their profile or changed their password (referring to the account they hadn't managed to access earlier).



Blaze blames Ralph for the login problems

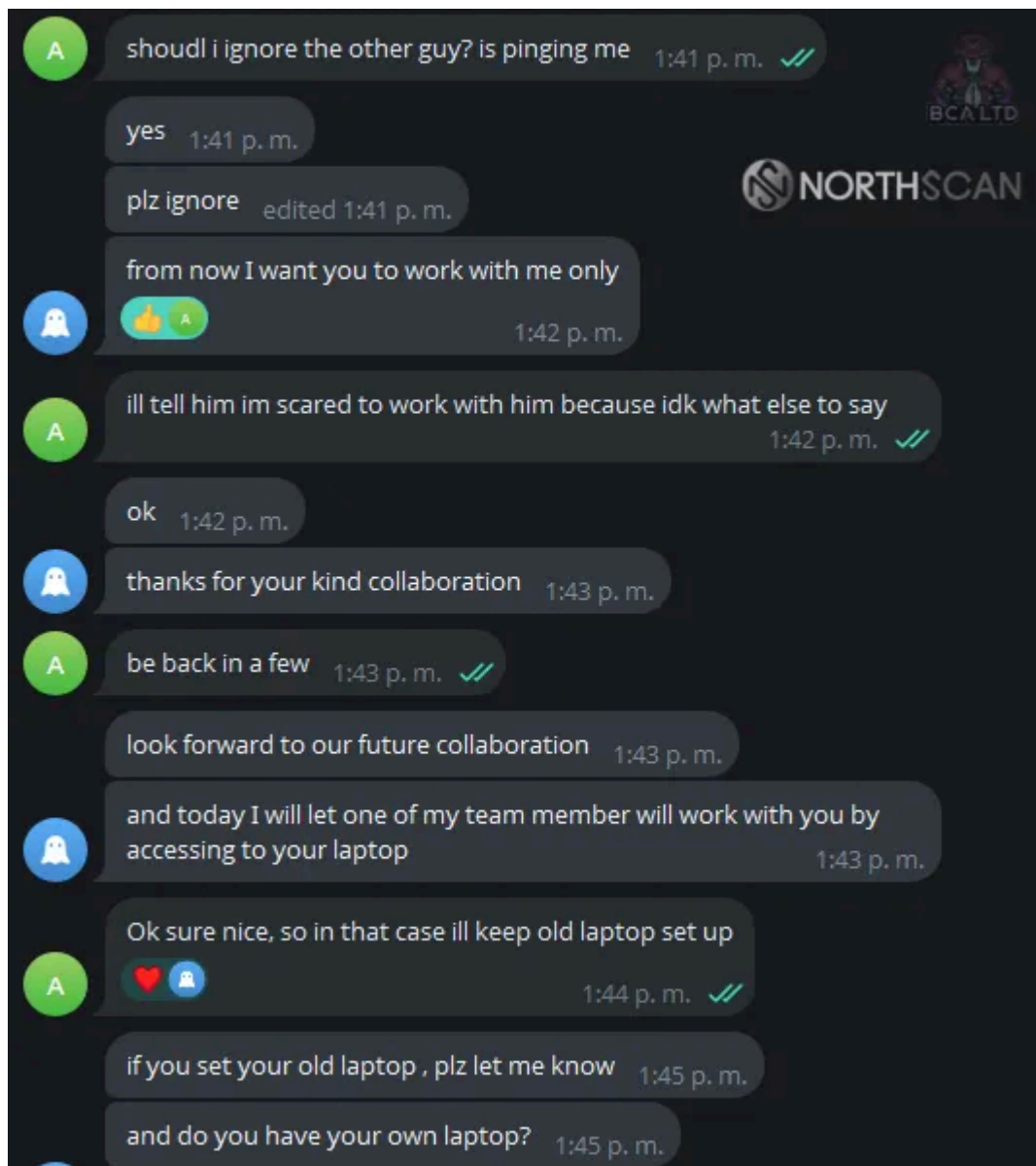
He then proceeded to insult **Ralph**, calling him “weird” and explaining that he could affect “his work” and that he wouldn’t like to take a risk with him. Instead, he would **assign one of his team members** to work on making things happen.



Blaze lost it over a fictitious character

He promised to get it together and get **everything working**, stating that after that we would **no longer need AnyDesk** (referring to him later installing **Google Remote Desktop**).

When **Heiner** asked if he should ignore the other guy, **Blaze** insisted he work exclusively with him from now on.



Blaze asks to ignore Ralph

He then shared that one of his team members would try to work with his laptop later that day. This was “Assassin”.

He appears on **Tape4** behind the exact same IP address as **Blaze**, which belongs to AstrillVPN.

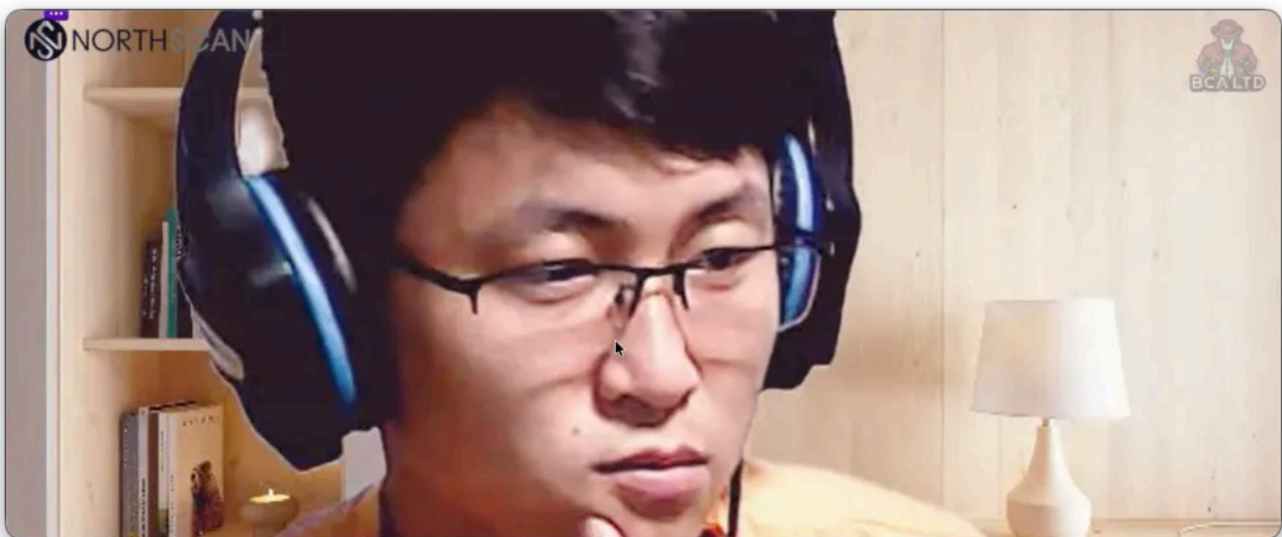
This hasty decision on his part helped us confirm they were **sharing infrastructure and assets**, and that they likely have **poor communication** between units, as the idea of **one recruiter stealing** an engineer from another seemed **totally plausible** to him. Additionally, when conducting job interviews at target companies, it's common to observe **multiple North Korean operatives** scheduling interviews for the same position **on the same day** (making it more obvious), suggesting a **lack of coordination** between different cells.

Until Next Time, Famous Chollima

This is not the last time we'll see **Famous Chollima**, or any other **North Korean** actor, infiltrating companies for **espionage and profit**.

This investigation was aimed at **collecting intelligence** from North Korean actors in a **novel way not practiced by any other lab to date**, by directly engaging with them and immersing ourselves in their operations. From that standpoint, we understand this publication will help to better understand this threat, their structure, behaviour, tactics, techniques and procedures, and contextualize their skillset and toolset, which now **heavily relies on AI**.

If you are an **employer**, conduct rigorous **KYC controls** and **background checks** when hiring new positions. **Train** your talent acquisition teams to detect red flags early and don't be afraid to **share this story** with your candidates, making sure they understand that the "*software company*" that offered them something *too good to be true* may not be so legitimate.



Always doubt

If you are **seeking employment**, beware of **malicious coding challenges**, never conduct interviews on your company's equipment and check with companies if someone attempting to hire you out of the blue is affiliated with them.

The same goes for those looking to **raise funds** for their projects: beware of meetings with **fake VCs**, never open their attachments without prior checking their safety, and overall, if something is too good to be true, then maybe it is.



Always double check

If you are a **security professional**, don't be afraid to confront these threats, nor to ask for help in the community. Raise **awareness** in your organization and spread the word about their activities. With everyone knowing what to look for, we remain safer.

And for the rest, don't forget to **smile**.



Smile

How ANY.RUN Supports Investigations Like This

This operation shows how difficult it is to track human-driven intrusions, especially when they rely on social engineering instead of malware. By moving the actors into controlled ANY.RUN environments, every step, from their tooling to their network activity, became visible in real time.

The interactive sandbox and extended-runtime setups give researchers and SOC teams the same advantage: the ability to observe behavior as it unfolds, uncover hidden actions, and document full attack chains without risking real systems.

Cut MTTR by 21 minutes and reach 3x team performance

Integrate ANY.RUN's solutions in your SOC

[Request trial](#)

About ANY.RUN

ANY.RUN is a leading provider of interactive malware analysis and threat intelligence, helping security teams investigate attacks with real-time behavioral visibility. More than 15,000 organizations and over 500,000 analysts rely on the service to observe live execution, analyze suspicious files and URLs, and uncover hidden activity with an average 60-second time-to-verdict.

Alongside its sandbox, ANY.RUN provides continuously updated Threat Intelligence Feeds sourced from global telemetry, and TI Lookup, which offers instant enrichment by showing related samples, shared infrastructure, and historical context. Together, these capabilities give analysts a clear view of how threats behave and evolve, supporting faster, more confident decisions across SOC, DFIR, and threat-hunting workflows.

Further Reading

- [Contagious Interview on Mitre ATT&CK](#)
- [Interview with the Chollima on Bitso Quetzal Team](#)
- [InvisibleFerret & BeaverTail \(DPRK Malware\) on ANYRUN](#)
- [OtterCookie \(DPRK Malware\) on ANYRUN](#)
- [PyLangGhostRAT \(DPRK Malware\) on ANYRUN](#)
- [QRLog \(DPRK Malware\) on PHRACK #71](#)

- Contagious Interview on PagedOut #4 (Page 76)

IOCs

Indicators of Compromise

IPv4:194.33.45.162

URL:https[:]//t[.]me/peregrine423f

URL:aaronzeeshan[.]slack[.]com

URL:aaronsfazzy[.]slack[.]com

URL:https[:]//github[.]com/7codewizard

URL:https[:]//github[.]com/neymafullstack

URL:https[:]//github[.]com/swiftcode1121

URL:https[:]//github[.]com/ghost

URL:https[:]//calendly[.]com/7codewizard/30min

URL:https[:]//jackson-portfolio[.]vercel[.]app

URL:https[:]//www[.]linkedin[.]com/in/jackson-kidd-1680b2339/

URL:https[:]//us[.]bold[.]pro/my/jaron-gaston-241007104612

Email:kamaunjoroge296[.]gmail[.]com

Email:jacksonkidd216[.]gmail[.]com

Behavioural & Other Indicators

Nickname:Blaze

Nickname:Assassin

AnyDeskID:1686564829

AnyDeskID:1291915543

Password:123qwe!"#QWE

Password:123456

Search:"what is my location"

Search:"where is my location"

Search:"netspeedtest"

Search:"where is my ip"

Identified toolset

VPN and Remote Desktop Connection:

- AstrillVPN
- AnyDesk
- Google Remote Desktop

Browser Extensions:

- Simplify Copilot
- AIApply
- Saved Prompts (GPT)
- Final Round AI
- Authenticator[.]cc / otp[.]ee
- Google Remote Desktop

Commands observed:

- dxdiag
- systeminfo
- remoting_start_host.exe

Instant Messaging:

- Slack
- Telegram

Online platforms:

- Github
- LinkedIn
- ZipRecruiter
- Bold Pro
- Vercel
- Calendly

TTPs / ATT&CK

Reconnaissance

T1593.002 — Search Open Websites/Domains: Search Engines

Mass search for developers on GitHub

Initial Access

T1566 — Phishing

Mass phishing via GitHub pull requests targeting developers

Defense Evasion

T1090 — Proxy

Use of AstrillVPN to hide real location

Discovery

T1082 — System Information Discovery

Use of DXDIAG to obtain system information

Use of systeminfo to obtain system information

T1016 — System Network Configuration Discovery

Use of netspeedtest

Google searches for “where is my location”, “where is my ip”

T1614 — System Location Discovery

Use of netspeedtest

Google searches for “where is my location”, “where is my ip”

Command and Control

T1219 — Remote Access Software

Use of AnyDesk

Use of Google Remote Desktop

T1090 — Proxy

Use of AstrillVPN

Threat Intelligence

Malware Analysis

Lazarus Group

Cyber Threat Intelligence

Cybersecurity



Written by ANY.RUN

185 followers · 2 following

Empowering businesses with proactive security solutions: Interactive Sandbox, TI Lookup and Feeds. Sign up: <https://app.any.run#register>

No responses yet

